

Digital Constitutionalism

Approcci, metodologie e tecnologie per la protezione dei dati e la
garanzia dei diritti fondamentali

Studente: Niccolò Pecorari

Docente: Massimo Mecella

Scienza ed etica dei dati (33526)

Filosofia e Intelligenza Artificiale (L5 – 33526)

Fondamenti teorici e concettuali

1.1 Evoluzione del concetto di “dato personale”

La genesi della protezione dei dati personali è profondamente legata all’emergere della capacità computazionale su scala globale. Negli anni ’60 e ’70 del secolo scorso, IBM introdusse il celebre IBM System/360 (1964) e rese i mainframe uno standard per enti governativi e grandi imprese. La produzione di computer mainframe, di cui IBM resta leader di mercato, fu seguita dallo sviluppo dei primi Database Management System (DBMS) come l’Information Management System (IMS) di IBM, il quale permise per la prima volta nella storia di gestire e interrogare in modo strutturato enormi quantità di record. Prima dell’era dei mainframe, un’informazione veniva registrata in forma cartacea e inserita all’interno di “silos” non comunicanti. Pertanto, il gestore avrebbe dovuto recarsi fisicamente nell’archivio per recuperare l’informazione. Con la nuova potenza tecnica, il “dato” cessa di rappresentare un’informazione “passiva”, relegata a un singolo archivio fisico. L’avvento dei DBMS e delle tecnologie correlate trasformarono il dato in elemento dinamico, processabile e aggregabile, correlato e trasferibile. Tuttavia, questa capacità di elaborazione su larga scala generò un timore diffuso per la possibile sorveglianza di massa e la creazione di un “cittadino di vetro”, ovvero, un cittadino trasparente agli occhi del potere (statale o aziendale) che, al contrario, rimane opaco. In risposta alla crescente preoccupazione, non tardarono le prime reazioni legislative. Il primo testo normativo organico fu promulgato nel 1970 nello stato tedesco dell’Assia: la Hessisches Datenschutzgesetz. La legge si applicava quasi esclusivamente al settore pubblico e specificatamente ai loro sistemi di elaborazione automatizzata. Per la prima volta vennero introdotti i concetti di “Liceità” e “Finalità”, nei quali si affermava che i dati potevano essere raccolti e trattati solo per legittimi scopi e specifici permessi, “Riservatezza”, che prevedeva la protezione e la confidenzialità dei dati e imponeva l’obbligo di adottare misure tecniche per prevenire l’abuso e/o la perdita dei dati. Per quanto riguarda i Diritti dell’Individuo, sebbene in forma primordiale, venivano riconosciuti il cosiddetto “Diritto di Accesso”, ovvero il diritto di conoscere la tipologia di dati memorizzati sul proprio conto, e “il diritto di Rettifica”, il quale consentiva di avvertire l’autorità competente per effettuare modifiche e correzioni su dati errati. In questo quadro, la vera innovazione risiede nell’introduzione del “Datenschutzbeauftragter”, il Commissario per la Protezione dei Dati, una autorità indipendente avente potere di supervisione, controllo e ricezione reclami sull’operato governativo in materia di dati, garantendo così maggiore bilanciamento dei poteri¹. La nuova linea legislativa tedesca fu seguita anche in altri stati del Vecchio

¹ Simitis, S. (1987). "Reviewing Privacy in an Information Society". *University of Pennsylvania Law Review*, 135(3), 707-746

Continente. Nel 1973, la Svezia approvò il Datalagen (Data Act). Contrariamente alla legge regionale dell'Assia, quella svedese fu la prima legge nazionale onnicomprensiva sulla protezione dei dati al mondo. Oltre alla comprensione del diritto di Accesso e Rettifica, vennero introdotti due concetti cruciali: in primo luogo, fu istituita la Dataispektionen (l'Ispettorato Svedese per i Dati), che si può considerare la prima vera autorità garante della privacy a livello nazionale. Inoltre, introdusse un Sistema di Licenze Preventive. A differenza di altre leggi, il Datalagen non si limitava a "dettare" le regole ma richiedeva a qualunque tipologia di entità (sia pubblica che privata) di ottenere un permesso dalla Dataispektionen per la creazione di un database automatizzato contenente dati personali. La concessione avrebbe avuto luogo solo se, dopo accurata valutazione, il database non avrebbe causato uno "sconfinamento indebito" (otillbörligt intrång) nella privacy degli individui². Nel 1978, la Francia varò la celebre Loi Informatique e Libertés per rispondere all'inchiesta di Philippe Boucher intitolata "SAFARI ou la chasse aux Français"³. Il progetto SAFARI (Système Automatisé pour les Fichiers Administratifs et le Répertoire des Individus) era un progetto governativo avviato all'inizio degli anni '70. Il suo scopo era unificare e relazionare tutti i principali database governativi utilizzando il numero INSEE (il numero di sicurezza sociale) come unico identificatore per ogni cittadino. L'articolo di Boucher denunciava i rischi del progetto, facendo leva sul pericolo di uno stato di sorveglianza e sull'assenza di opacità in riferimento alle vite dei cittadini. L'impatto sull'opinione pubblica fu enorme, in quanto il ricordo dell'occupazione nazista e della conseguente consultazione dei registri anagrafici per identificare, rintracciare e perseguire le minoranze non era del tutto scomparso. Per rispondere allo scandalo pubblico, il governo francese istituì la Commission Informatique et Libertés per studiare il problema e si arrivò alla promulgazione della Loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés⁴. Questa legge introdusse la Commission Nationale de l'Informatique et des Libertés (CNIL) che, a differenza del Commissario dell'Assia o della Dataispektionen svedese, fu concepita come un'autorità amministrativa indipendente e collegiale, composta da parlamentari, magistrati ed esperti del settore. Questo nuovo modello di "commissione" indipendente divenne lo standard per le future Autorità Garanti europee. Inoltre, la legge francese, incluse il Diritto di Opposizione, il quale consentiva di opporsi, per motivi legittimi, al trattamento dei propri dati. Per quanto riguarda le concessioni e le licenze, la Francia, diversamente dalla rigidità svedese, decise di adottare un approccio più flessibile: la maggior parte dei trattamenti necessitava una semplice dichiarazione alla CNIL prima dell'attività e soltanto quelli inerenti alle informazioni ad alto rischio (es. dati sensibili) avrebbero richiesto una autorizzazione esplicita. Alla fine degli anni '70, il mondo viveva una condizione paradossale. Da un lato, una gran parte dell'economia globale si configurava sempre più dipendente dai flussi di dati transnazionali per servizi essenziali come transazioni bancarie, prenotazioni aeree e qualunque attività effettuata dalle multinazionali. Dall'altro lato, i singoli paesi (Germania, Svezia, Francia) iniziavano ad elaborare barriere normative per proteggere la privacy degli individui. Questo fervore giuridico destò diversi dubbi e numerose preoccupazioni alla comunità economica. Il timore era legato alla possibilità che queste leggi nazionali potessero essere utilizzate come una forma di "protezionismo dei dati" (data protectionism). In altre parole, il timore riguardava la possibilità che i paesi potessero bloccare i flussi di dati, con la giustificazione della "privacy", soffocando il commercio internazionale⁵. Nel 1980, l'OCSE, che nel dibattito economico dei dati fu l'ente che esplicitò maggiore preoccupazione, elaborò le celebri Linee Guida. L'obiettivo dell'OCSE non riguardava l'aumento delle misure di protezione ma trovare un "comune denominatore", un insieme minimo di regole che fosse sufficiente a rassicurare l'opinione pubblica e proteggere la privacy, fosse abbastanza flessibile da essere adottato in paesi con sistemi giuridici di diverso tipo e garantisse che i

² https://www.riksdagen.se/sv/dokument-lagar/dokument/svensk-forfattningssamling/datalag-1973289_sfs-1973-289

³ Boucher, P. (1974). "SAFARI ou la chasse aux Français". *Le Monde*, 21 marzo 1974.

⁴ Loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés

⁵ Organisation for Economic Co-operation and Development (OECD). (1980). *Guidelines on the Protection of Privacy and Transborder Flows of Personal Data*. Parigi: OECD Publishing.

paesi firmatari si impegnassero a non interrompere i flussi di dati verso altri paesi che aderivano allo standard. Il documento, infatti, venne intitolato “Linee Guida sulla Protezione della Privacy e sui Flussi Transfrontalieri di Dati Personali”. Le Linee Guida del 1980 (aggiornate poi nel 2013) hanno codificato per la prima volta a livello internazionale, gli otto principi che costituiscono ancora oggi il fulcro dell’Articolo 5 del GDPR. Tra questi, troviamo il Principio di limitazione della raccolta (Collection Limitation), che prevede la sola raccolta dei dati necessari tramite mezzi leciti e consenso, il Principio della qualità dei dati (Data Quality), grazie al quale i dati devono essere pertinenti allo scopo, esatti, completi e aggiornati, il Principio di specificazione delle finalità (Purpose Specification), che stabilisce che le finalità della raccolta devono essere specificate “al più tardi al momento della raccolta” e l’uso successivo è limitato a tali finalità, il Principio di limitazione dell’uso (Use Limitation), nel quale si afferma che i dati non devono essere utilizzati o comunicati per finalità diverse da quelle specificate. A seguire, troviamo il Principio delle garanzie di sicurezza (Security Safeguards), per cui i dati devono essere protetti con misure di sicurezza ragionevoli, il Principio di apertura (Openness), il quale afferma che deve esserci trasparenza sulle pratiche di gestione dei dati e sull’identità del titolare, il Principio di Partecipazione Individuale (Individual Participation), che garantisce agli individui il diritto di accedere ai propri dati e chiederne la rettifica o la cancellazione, il Principio di accountability (Accountability), il quale attesta che il titolare del trattamento (data controller) è responsabile del rispetto di questi principi. Il documento, sebbene non giuridicamente vincolante, ebbe notevole impatto, in quanto fornì il lessico e la struttura concettuale per tutte le future leggi sulla privacy. Il vero salto paradigmatico, che segna il passaggio da un approccio più vicino ad una “data security” verso una “data protection” antropocentrica trova le sue radici nella sentenza della Corte Costituzionale Federale tedesca sul censimento (Volkszählungsurteil) del 15 dicembre 1983. Quel giorno, la Corte decretò l’esistenza di un nuovo diritto fondamentale, derivato dalla dignità umana (Articolo 1 della Legge Fondamentale tedesca) e dal diritto al libero sviluppo della personalità (Articolo 2): il “Recht auf informationelle Selbstbestimmung”, in italiano “Diritto all’Autodeterminazione Informativa. La Corte stabilì che, nell’era dell’elaborazione dati, un individuo deve poter “decidere fondamentalmente quando e entro quali limiti le informazioni relative alla sua vita personale debbano essere comunicate”⁶. Questo concetto si configura come un netto distacco dalla concezione anglosassone di privacy, definita nel 1890 da Warren e Brandeis come “the right to be let alone” (il diritto a essere lasciati soli)⁷. La privacy, dunque, è definita come un diritto difensivo, statico, un diritto alla segretezza e alla non intrusione nella propria sfera privata. Al contrario, l’autodeterminazione informativa, e di conseguenza il data protection europeo, è un diritto proattivo, dinamico e relazionale: non mira a nascondere i dati, ma a gestirne il flusso, garantendo all’individuo il controllo sulle proprie informazioni anche quando sono lecitamente in mano a terzi. In merito alla questione, Stefano Rodotà ha efficacemente affermato che si tratta di un diritto fondamentale per la costruzione dell’identità e per la partecipazione democratica, in quanto un vero “diritto di avere diritti” nella società dell’informazione⁸. Per comprendere al meglio gli effetti di quella che si può definire svolta “antropocentrica”, occorre citare la Carta dei Diritti Fondamentali dell’Unione Europea (Nizza, 7 dicembre 2000). Prima del nuovo millennio, la protezione dati a livello UE era disciplinata dalla Direttiva 95/46/CE, la quale aveva un duplice fondamento: la tutela dei diritti fondamentali (in accordo con l’Articolo 8 della Convenzione Europea dei Diritti dell’Uomo) e la necessità di armonizzare le leggi nazionali per garantire la libera circolazione dei dati all’interno del Mercato Unico (Articolo 100 del Trattato CE)⁹. L’approccio era ancora ibrido, a metà tra diritti e commercio, ma con la Carta di Nizza fu attuata una distinzione concettuale netta. Nel Capo II (“Libertà”) della Carta, troviamo l’Articolo 7 - Rispetto della vita privata e familiare e l’Articolo 8 - Protezione dei dati di carattere personale. Nel primo citato, si ricalca la tradizione della privacy

⁶ Bundesverfassungsgericht (Corte Costituzionale Federale Tedesca). (1983). *Sentenza sul censimento (Volkszählungsurteil)*.

⁷ Warren, S. D., & Brandeis, L. D. (1890). "The Right to Privacy". *Harvard Law Review*, 4(5), 193-220.

⁸ Rodotà, S. (2012). *Il diritto di avere diritti*. Bari: Laterza.

⁹ Direttiva 95/46/CE del Parlamento europeo e del Consiglio, del 24 ottobre 1995.

“classica”, basata sull’Articolo 8 della Convenzione Europea dei Diritti dell’Uomo): “Ogni individuo ha diritto al rispetto della propria vita privata e familiare, del proprio domicilio e delle proprie comunicazioni”. L’Articolo 8 - Protezione dei dati di carattere personale presenta l’innovazione. Esso crea un diritto fondamentale nuovo e autonomo, separato dalla privacy: "1. Ogni individuo ha diritto alla protezione dei dati di carattere personale che lo riguardano. 2. Tali dati devono essere trattati secondo il principio di lealtà, per finalità determinate e in base al consenso della persona interessata o a un altro fondamento legittimo previsto dalla legge. 3. Ogni individuo ha il diritto di accedere ai dati raccolti che lo riguardano e di ottenerne la rettifica. 4. Il rispetto di tali norme è soggetto al controllo di un'autorità indipendente.". Nessun altro documento costituzionale di tale livello opera questa distinzione. L’articolo 8 non si limita a proteggere la segretezza dei dati, ma stabilisce il diritto a un trattamento equo (lealtà, finalità), il controllo (accesso, rettifica), enforcement (autorità indipendente). Al momento della sua proclamazione, la Carta aveva solo un valore dichiarativo, era una “soft law”. La sua forza giuridica era incerta e veniva utilizzata dalle Corti principalmente come strumento interpretativo. Il 1° dicembre 2009 entra in vigore il Trattato di Lisbona, il quale va a consolidare l’Articolo 6, paragrafo 1, del Trattato sull’Unione Europea di Maastricht (1992): ““L’Unione riconosce i diritti, le libertà e i principi sanciti dalla Carta dei diritti fondamentali dell’Unione europea [...], che ha lo stesso valore giuridico dei trattati”¹⁰. Questo singolo articolo ha trasformato la Carta da dichiarazione politica a diritto primario dell’Unione, giuridicamente vincolante per le istituzioni UE e per gli Stati membri. Questa “costituzionalizzazione” ha avuto due effetti: in primo luogo, ha fornito la Base Giuridica Operativa grazie all’introduzione dell’Articolo 16 del TFUE (Trattato sul Funzionamento dell’Unione Europea). Questo articolo, che si può definire il “braccio operativo” dell’Articolo 8 della Carta, consente al Parlamento europeo e al Consiglio di legiferare in materia di protezione dei dati, aprendo la strada al GDPR (che infatti si basa sull’Articolo 16 TFUE)¹¹. Inoltre, la costituzionalizzazione ha concesso alla Corte l’utilizzo degli Articoli 7 e 8 della Carta come parametro per giudicare la validità di altre leggi europee. L’esempio più eclatante è la sentenza *Digital Rights Ireland* (2014), in cui la Corte ha invalidato l’intera Direttiva sulla conservazione dei dati (*Data Retention*) perché violava in modo sproporzionato i diritti sanciti dagli Articoli 7 e 8 della Carta¹². Dunque, L’Unione Europea ha definito in prima istanza filosoficamente la protezione dei dati come un diritto fondamentale autonomo e poi le ha conferito il massimo valore giuridico possibile, rendendola un principio costituzionale vincolante che legittima l’adozione del GDPR e permette alle corti di invalidare leggi non conformi.

1.2 Principi generali della protezione dei dati

I principi filosofici e giuridici discussi nel paragrafo precedente, derivanti dall’autodeterminazione informativa e codificati nell’Articolo 8 della Carta, si traducono operativamente nell’Articolo 5 del GDPR, “Principi applicabili al trattamento dei dati personali”¹³. Prima di proseguire con l’approfondimento delle novità introdotte, è necessario fornire una definizione del Regolamento. Il Regolamento Generale sulla Protezione dei Dati (GDPR) è stato adottato il 27 aprile 2016 ed è divenuto definitivamente operativo a partire dal 25 maggio 2018. Essendo un “Regolamento”, differentemente da una “Direttiva”, esso è direttamente applicabile in tutti gli Stati membri dell’UE senza che sia “recepito” nelle leggi nazionali. L’Articolo 5 del GDPR è la norma più fondamentale del Regolamento, infatti, la sua violazione è la radice di quasi ogni sanzione. L’Articolo elenca sei principi cardine che

¹⁰ Trattato sull’Unione Europea (TUE) (Versione consolidata 2012/C 326/01).

¹¹ Trattato sul Funzionamento dell’Unione Europea (TFUE) (Versione consolidata 2012/C 326/01).

¹² Corte di Giustizia dell’Unione Europea (CJEU). (2014). *Sentenza nelle cause riunite C-293/12 e C-594/12, Digital Rights Ireland Ltd e Seitlinger e altri*.

¹³ Parlamento europeo e Consiglio. (2016). *Regolamento (UE) 2016/679 (GDPR)*. Articolo 5, "Principi applicabili al trattamento di dati personali".

riprendono ed evolvono la tradizione dell'OCSE (1980) e la Direttiva 95/46/CE. Il primo è quello di Liceità, correttezza e trasparenza (art. 5.1.a), secondo cui il trattamento deve avere base giuridica valida tra quelle elencate nell'Art. 6 (consenso, contratto, obbligo legale, interesse vitale, compito pubblico, legittimo interesse). La "correttezza" impone un agire leale, la "trasparenza" impone l'obbligo di informare l'interessato (Art. 13 e Art. 14) in modo chiaro, semplice e accessibile. A seguire, troviamo il principio di Limitazione delle finalità (art. 5.1.b), che si può considerare il principio "architettonico", in cui si afferma che i dati devono essere raccolti per "finalità determinate, esplicite e legittime" e non possono essere trattati ulteriormente in modo incompatibile. Questo vieta la cosiddetta "function creep" (la deriva degli scopi) e impone una rigorosa analisi di compatibilità per ogni uso secondario. Il terzo principio è quello della Minimizzazione dei dati (art. 5.1.c), secondo cui i dati devono essere "adeguati, pertinenti e limitati a quanto necessario" (principio di necessità) e funge da fondamento della Privacy by Design (Art. 25). Il quarto principio è quello di Esattezza (art. 5.1.d), in cui si afferma che i dati devono essere curati e aggiornati e si collega direttamente al diritto di rettifica dell'interessato (Art. 16). Il quinto principio è quello di Limitazione della conservazione (art. 5.1.e), secondo il quale i dati non possono essere conservati in forma identificabile "per un arco di tempo superiore al conseguimento delle finalità". Impone, dunque, la creazione di "data retention policy" e la successiva cancellazione o anonimizzazione. L'ultimo principio dell'Articolo 5 è quello di Integrità e riservatezza (art. 5.1.f), il "pilastro" della sicurezza. Esso impone al titolare di proteggere i dati da trattamenti illeciti, perdita o distruzione, mediante "misure tecniche e organizzative adeguate" (come viene specificato nell'Art. 32). La vera rivoluzione del GDPR, però, è contenuta nel secondo paragrafo, l'Articolo 5.2, nel quale è contenuto il principio di "Accountability" (Responsabilizzazione). Esso recita: "Il titolare del trattamento è competente per il rispetto del paragrafo 1 e in grado di provarlo". Nella vecchia Direttiva 95/46/CE, l'approccio era reattivo, ovvero l'autorità aveva il compito di provare la violazione. Con il GDPR, l'approccio diventa proattivo: il titolare (il data controller) non deve solo essere conforme, ma deve poter dimostrare in ogni momento di aver adottato tutte le misure necessarie per diventare e/o rimanere conforme. L'Accountability, dunque, non è da considerare un principio di carattere astratto, ma il vero motore che mette in azione tutti gli obblighi pratici del GDPR: tra questi troviamo l'obbligo di tenuta dei Registri dei trattamenti (Art. 30) per mappare i dati, l'obbligo di condurre una Valutazione d'Impatto (DPIA) (Art. 35) per i trattamenti a rischio, l'adozione di misure di Privacy by Design e by Default (Art. 25) e l'obbligo di documentare le proprie decisioni. Se dovessimo scegliere l'emblema della supremazia dei diritti fondamentali dell'individui sui meri interessi economici questo sarebbe il Diritto all'Oblio. Quest'ultimo è nato in via giurisprudenziale, prima che venisse redatto il GDPR, nella celebre sentenza Google Spain (2014)¹⁴. Il caso riguardava Mario Costeja González, cittadino spagnolo che aveva richiesto a Google di rimuovere dai risultati di ricerca associati alla sua identità i link a vecchi articoli di giornale che menzionavano un pignoramento che era stato già risolto da tempo. La Corte di Giustizia UE fu chiamata a decidere se un motore di ricerca fosse un "titolare del trattamento" e se Costeja avesse diritto a far "cadere nell'oblio" quella notizia. La sentenza della corte stabilì due punti rivoluzionari: il primo sancì che Google è un titolare, in quanto l'indicizzazione e la presentazione dei risultati sono un "trattamento di dati personali" e il motore di ricerca (Google Inc.) ne è il titolare. In secondo luogo, la Corte affermò che, sebbene il trattamento fosse inizialmente lecito (le notizie erano veritiere), con il passare del tempo i diritti fondamentali dell'individuo interessato (Art. 7 e 8 della Carta) potevano prevalere sull'interesse economico del motore di ricerca e sull'interesse del pubblico all'informazione. I dati, nonostante l'accuratezza, erano divenuti "inadeguati, irrilevanti o non più pertinenti" rispetto alla finalità iniziale (16, par. 94). La Corte, quindi, non impose a Google di cancellare la notizia dalla fonte (il sito del giornale) ma di de-indicizzarla. Il GDPR ha recepito e codificato questa spinta giurisprudenziale

¹⁴ Corte di Giustizia dell'Unione Europea (CJEU). (2014). *Sentenza Google Spain SL e Google Inc. contro Agencia Española de Protección de Datos (AEPD) e Mario Costeja González*.

nell'Articolo 17, "Diritto alla cancellazione ('diritto all'oblio')"¹⁵. L'Articolo 17 è più ampio della semplice de-indicizzazione e impone al Titolare la cancellazione fisica dei dati quando questi non sono più necessari rispetto alle finalità, quando il consenso viene revocato o quando il trattamento è illecito. L'affermazione di principi così complessi e di diritti giurisprudenziali come l'oblio ha reso manifesta l'inadeguatezza della Direttiva 95/46/CE, aprendo la strada ad una riforma radicale. La sezione successiva sarà incentrata sull'architettura e le motivazioni del Regolamento Generale sulla Protezione dei Dati, approfondendo gli aspetti più importanti dello strumento che ha messo in atto la transizione verso un approccio di data protection antropocentrico.

Il modello europeo e il GDPR

2.1 Origini e contesto politico del GDPR

Il GDPR, anche noto come Regolamento (UE) 2016/279, non trova la sua genesi casualmente, ma si può considerare il risultato di un processo politico e legislativo reso necessario dal progressivo fallimento dello strumento normativo precedente, ovvero, la Direttiva 95/46/CE¹⁶. Sebbene quest'ultima avesse rappresentato un modello all'avanguardia nel 1995, un'era pre-Google e pre-social media, due decenni di rivoluzione tecnologica l'avevano resa obsoleta. In particolare, la Direttiva soffriva di due carenze strutturali divenute insostenibili. La prima era di carattere giuridico, in quanto, essendo una "direttiva", essa non era direttamente applicabile, ma richiedeva a ciascuno Stato membro di essere "recepita" nel proprio ordinamento nazionale. Questo processo portò a quella che è stata definita una "frammentazione giuridica"¹⁷. Sebbene l'obiettivo fosse l'armonizzazione, il risultato fu un mosaico di 28 leggi nazionali sulla privacy, divergenti su punti chiave come il ruolo dell'autorità di controllo, il regime sanzionatorio e l'interpretazione di concetti fondamentali come il "consenso". Per un'impresa operante in più paesi UE, questo significava costi di conformità (compliance) moltiplicati e un'incertezza del diritto che fungeva da freno diretto allo sviluppo del Mercato Unico Digitale. La seconda carenza era di tipo tecnologico, in quanto la Direttiva era stata concepita per un mondo di database statici, PC e moduli cartacei e, dunque, risultava del tutto impreparata a governare la massiccia ondata tecnologica degli anni 2000 di cui fanno parte la nascita dei social network e la monetizzazione dei dati relazionali, l'avvento degli smartphone e la raccolta di dati di geolocalizzazione, l'affermazione del cloud computing che polverizzava la localizzazione fisica dei dati, lo sviluppo del targeting comportamentale (behavioral advertising) e della profilazione su vasta scala. Di fronte a questa realtà, la Commissione Europea, già nel 2012 sotto le volontà della Vicepresidente Viviane Reding, presentò la sua proposta di riforma¹⁸. L'obiettivo era duplice e rifletteva la "doppia anima" dell'UE, sancita dal Trattato di Lisbona: in primo luogo, proponeva di sostituire la frammentazione della Direttiva con un Regolamento unico. Questo per garantire la certezza del diritto, ridurre i costi di compliance per le imprese e creare un livello di parità per tutti i protagonisti del Mercato Unico Digitale (DSM). In quest'ottica, la fiducia dei consumatori sulla gestione dei loro dati veniva considerata come la "valuta"

¹⁵ Parlamento europeo e Consiglio. (2016). *Regolamento (UE) 2016/679 (GDPR)*. Articolo 17, "Diritto alla cancellazione ('diritto all'oblio')".

¹⁶ Direttiva 95/46/CE del Parlamento europeo e del Consiglio, del 24 ottobre 1995, *relativa alla tutela delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati*.

¹⁷ Voigt, P., & von dem Bussche, A. (2017). *The EU General Data Protection Regulation (GDPR): A Practical Guide*. Springer.

¹⁸ Commissione Europea. (2012). *Proposta di Regolamento del Parlamento europeo e del Consiglio concernente la tutela delle persone fisiche con riguardo al trattamento dei dati personali e la libera circolazione di tali dati (Regolamento generale sulla protezione dei dati)*. COM(2012) 11 final.

fondamentale per sbloccare il potenziale dell'economia digitale¹⁹. Il secondo obiettivo era di carattere Costituzionale (garantire i diritti fondamentali), basato sul Trattato di Lisbona. Questo processo negoziale, iniziato nel 2012, fu profondamente influenzato da un evento che scosse l'opinione pubblica di ogni stato del mondo: le rivelazioni di Edward Snowden sulla sorveglianza di massa nel 2013 (scandalo PRISM). Questo scandalo aumentò la pressione politica per rafforzare le tutele dei cittadini. Il risultato fu un testo finale ultimato nel 2016, significativamente più robusto rispetto alla proposta iniziale, con sanzioni più severe, un ambito di applicazione extraterritoriale più esplicito e un rafforzamento dei diritti degli interessati. Il GDPR, dunque, si configura come un compromesso politico di alto livello, uno strumento per il mercato unico che funge, contemporaneamente, da scudo per i diritti fondamentali in un mondo globalizzato e digitalizzato.

2.2 Architettura normativa del GDPR

L'architettura del GDPR è un sistema complesso e interconnesso, progettato per superare l'approccio reattivo della Direttiva 95/46/CE, e si fonda su tre pilastri importanti: una chiara definizione dei ruoli (la governance), un elenco tassativo di condizioni di liceità (le regole) e un insieme di diritti azionabili per l'interessato (il controllo). Il collante che tiene insieme questa struttura è il principio-motore dell'Accountability. Il regolamento attribuisce responsabilità specifiche definendo in modo netto i "protagonisti" del trattamento. Nell'Articolo 4, viene effettuata la distinzione tra Titolare del trattamento (Data Controller), il Responsabile del trattamento (Data Processor), il Responsabile della Protezione dei Dati (RPD) e l'Autorità di Controllo. Il Titolare è la persona fisica o giuridica (azienda, ente pubblico) che, singolarmente o insieme ad altri, "determina le finalità e i mezzi del trattamento" (Art. 4.7). Si può definire in maniera intuitiva il "chi" e il "perché". Il Titolare è il principale responsabile della compliance (come sancito dall'Art. 24) ed è il soggetto su cui ricade l'onere dell'Accountability. Il Responsabile del trattamento è la persona fisica o giuridica che "tratta i dati personali per conto del Titolare" (Art. 4.8). È il fornitore di servizi (es. un provider cloud, un'agenzia di marketing, un consulente paghe). Il Responsabile non decide le finalità, ma agisce solo su istruzione documentata del Titolare. La sua nomina deve essere regolata da un contratto o atto giuridico specifico (Art. 28), che definisce i suoi obblighi, incluse le misure di sicurezza. Il Responsabile della Protezione dei Dati è la figura, resa obbligatoria in casi specifici (es. trattamento dati sensibili), che funge da supervisore interno indipendente (Art. 37 e Art. 39). Il RPD si occupa di informare, consigliare e sorvegliare il Titolare o il Responsabile, fungendo anche da punto di contatto per gli interessati e per l'Autorità. Infine, l'Autorità di Controllo, secondo l'Articolo 51, si occupa di sorvegliare l'applicazione del regolamento²⁰. Un trattamento dati è considerato lecito solo se si fonda su una delle sei basi giuridiche elencate nell'Articolo 6. La scelta della base giuridica corretta è la prima e più importante decisione di compliance del Titolare. Tra queste troviamo il Consenso, ovvero, l'interessato ha espresso il consenso per una o più specifiche finalità; il Contratto, che implica che il trattamento è necessario all'esecuzione di un contratto (es. per spedire un prodotto acquistato online); l'Obbligo legale, nel quale si prevede che il trattamento è necessario per adempiere un obbligo legale (es. conservazione delle fatture per fini fiscali); Interesse vitale, come nel caso di un pronto soccorso, quando il trattamento è necessario per la salvaguardia degli interessi vitali dell'interessato; Interesse pubblico, quando il trattamento è necessario per l'esecuzione di un compito di interesse pubblico o connesso all'esercizio di pubblici poteri; Interesse legittimo, ovvero il trattamento è necessario per il perseguimento del legittimo interesse del titolare (es. marketing diretto), a condizione che non prevalgano gli interessi o i diritti e le libertà fondamentali dell'interessato. Quest'ultima base, è importante specificarlo, non è

¹⁹ Commissione Europea. (2015). *Comunicazione sulla Strategia per il mercato unico digitale in Europa*. COM(2015) 192 final

²⁰ European Data Protection Board (EDPB). *Sito Ufficiale*.

utilizzabile dalle autorità pubbliche. Contrariamente al senso comune, il consenso non è la base giuridica principale, ma solo una delle 6. Tuttavia, il GDPR ne ha ridefinito i requisiti in modo radicale. L'Articolo 7 stabilisce che il consenso deve essere "prestato liberamente, specifico, informato e inequivocabile", manifestato attraverso un'azione positiva (es. una casella da spuntare, non pre-spuntata). Deve essere granulare (un consenso per ogni finalità), dimostrabile dal Titolare e revocabile con la facilità con cui è stato concesso. Il Capo III del GDPR (Articoli 12-23) costituisce la cosiddetta "Carta dei Diritti" dell'interessato, spostando il potere di controllo verso l'individuo. Oltre alla trasparenza (ovvero, il diritto ad un'informatività chiara, Articoli 13-14), i diritti chiave includono il Diritto di Accesso (Art. 15), il diritto di sapere se è in corso un trattamento, quali dati vengono trattati, per quali finalità e la possibilità di ottenerne una copia, il Diritto di Rettifica (Art. 16), quello di correggere dati inesatti, il Diritto alla Cancellazione (Oblio) (Art. 17), come discusso in precedenza, il diritto di far cancellare i dati (es. Google Spain, se non più necessari, se il consenso è revocato), il Diritto di Limitazione (Art.18), ovvero il diritto di "congelare" il trattamento (es. in caso di contestazione). A seguire troviamo una delle grandi novità del Regolamento: il Diritto alla Portabilità (Art. 20), che è il diritto di ricevere i propri dati in formato strutturato e leggibile da dispositivo automatico e trasmetterli a un altro Titolare. Successivamente, il Diritto di Opposizione (Art. 21), il diritto di opporsi in qualsiasi momento, per motivi connessi alla propria situazione particolare, ai trattamenti basati su interesse legittimo o pubblico e, infine, il Diritto relativo ai Processi Decisionali e Automatizzati (Art. 22), il diritto di non essere sottoposti a decisioni basate unicamente sul trattamento automatizzato (profilazione inclusa) che producano effetti giuridici o incidano significativamente sulla persona. Quest'ultimo è un diritto fondamentale nell'era dell'Intelligenza Artificiale, che garantisce, salvo alcune eccezioni, un intervento "umano". Come menzionato nella prima parte del saggio, il Principio di Accountability (Art. 5.2) è l'obbligo del Titolare di "essere in grado di comprovare" il rispetto dei principi. Questo si traduce nell'obbligo (Art. 24) di "mettere in atto misure tecniche e organizzative adeguate". Il principio viene attuato nell'Articolo 25: "Protezione dei dati fin dalla progettazione e per impostazione predefinita" (Privacy by Design & by Default). La Privacy by Design impone al Titolare di integrare le garanzie della protezione dei dati (es. minimizzazione, pseudonimizzazione) fin dal momento della progettazione, ad esempio, di un nuovo software. La privacy deve essere concepita come un requisito di progettazione e non come un plus facoltativo. La Privacy by Default impone che le impostazioni iniziali di un prodotto o servizio siano quelle più protettive per la privacy (es. un profilo social impostato come "privato" e non "pubblico" al momento dell'iscrizione). Questa architettura, che lega ruoli, regole, diritti e un approccio proattivo, crea un sistema di governance dei dati completo e pensato per resistere alle sfide dell'evoluzione tecnologica. È importante sottolineare che un impianto normativo, per quanto sofisticato, rimane vigoroso grazie alla sua capacità di essere applicato. Dunque, nella sezione successiva, verrà posta attenzione agli strumenti di "enforcement" del GDPR.

2.3 Applicazione ed enforcement

L'architettura normativa del GDPR, rispetto alla Direttiva 95/46/CE, è sostenuta da un apparato di enforcement radicalmente rafforzato. L'obiettivo era duplice: garantire un'applicazione armonizzata in tutti gli Stati membri e dare alle autorità poteri sanzionatori capaci di colpire anche i giganti della tecnologia globali. Per risolvere il problema della frammentazione che affliggeva la Direttiva, il GDPR ha introdotto il meccanismo dello "Sportello Unico" (OSS, One-Stop-Shop) (Articoli 56-60). Il principio è che un Titolare o Responsabile che effettua un trattamento transnazionale deve relazionarsi principalmente con un'unica autorità: la Lead Supervisory Authority (LSA). Questa è, in genere, l'autorità dello Stato membro in cui l'azienda ha il suo stabilimento principale nell'UE. La LSA prende in gestione il caso, ma non effettua decisioni autonomamente. Deve cooperare con le altre autorità di controllo "interessate" (ovvero, quelle dei paesi in cui i cittadini sono coinvolti) attraverso un meccanismo di cooperazione e coerenza (Art. 60). Se sorge un disaccordo tra le autorità, il caso viene

reinviato alla European Data Protection Board (EDPB), che ha il potere di adottare una decisione vincolante (come stabilito nell'Art. 65). Nonostante il sistema sia stato progettato per l'efficienza, non è risultato esente da critiche. Alcuni sostengono che abbia creato un "bottleneck" presso l'autorità irlandese (DPC), accusata da altre autorità e da attivisti, come Max Schrems, di eccessiva lentezza e clemenza nella gestione dei casi contro le grandi piattaforme tecnologiche che hanno la loro sede europea a Dublino²¹. Tralasciando alcune perplessità, il vero "martello" del GDPR risiede nell'Articolo 83, che ha dotato le Autorità di Controllo di poteri sanzionatori senza precedenti. Il Regolamento stabilisce un sistema a due livelli per le sanzioni amministrative pecuniarie, le quali devono essere "effettive, proporzionate e dissuasive". La prima, riguarda una sanzione fino a dieci milioni di euro o, per le imprese, fino al 2% del fatturato mondiale totale annuo dell'esercizio precedente (se superiore). Questo viene applicato a violazioni di obblighi di tipo organizzativo, come quelli relativi alla Privacy by Design (Art. 25), alla tenuta dei Registri (Art. 30) o alla nomina del DPO (Art. 37). La seconda è una sanzione fino a venti milioni di euro o, per le imprese, fino al 4% del fatturato mondiale totale annuo dell'esercizio precedente (se superiore). Questa sanzione, che è la più elevata, è riservata alle violazioni dei fondamenti del Regolamento come la violazione dei Principi di Base (Art. 5), violazione delle Basi Giuridiche e del Consenso (Articoli 6 e 7), violazione dei Diritti degli Interessati (Capo III) e violazione delle norme sui Trasferimenti internazionali (Capo V, Art. 83.5). L'introduzione di sanzioni parametriche sul fatturato mondiale si è configurata come la mossa strategica che ha reso il GDPR temibile su scala globale. Per la prima volta nella storia, la non-compliance può avere un impatto finanziario devastante, trasformando la privacy da costo legale a rischio di business primario. Il pilastro più controverso (e geopoliticamente rilevante) nel GDPR è di sicuro il suo ambito di applicazione territoriale (Art. 3) e la gestione dei flussi di dati verso paesi terzi (Capo V). L'articolo 3.2 stabilisce che il GDPR si applica anche a Titolari e Responsabili non stabiliti nell'UE, qualora questi offrano beni o servizi (anche gratuiti) a interessati dell'UE, o ne monitorino il comportamento (es. la profilazione online). Questo articolo ha costretto le aziende statunitensi, cinesi o giapponesi a adeguarsi alla normativa UE. Il capo V (Articoli 44-50) stabilisce che un dato personale può lasciare l'Unione Europea solo se la sua protezione non viene compromessa e questo può avvenire attraverso tre principali canali: la Decisione di Adeguatezza (Art. 45), per mezzo della quale la Commissione Europea riconosce che un paese terzo garantisce un livello di protezione "sostanzialmente equivalente" a quello dell'UE²²; Garanzie Adeguate (Art. 46), il quale prevede che, in assenza di adeguatezza, il Titolare può trasferire i dati se fornisce garanzie specifiche, come le Clausole Contrattuali Standard (SCCs) approvate dalla Commissione, o le Binding Corporate Rules (BCRs) per i gruppi multinazionali; Deroghe (Art. 49), soltanto in casi specifici e non sistematici (es. consenso esplicito di un contratto). Tuttavia, l'architettura presentata è stata scossa nel luglio del 2020 dalla sentenza della Corte di Giustizia dell'UE nel caso *Data Protection Commissioner c. Facebook Ireland Ltd e Maximillian Schrems* ("Schrems II")²³. La Corte, chiamata a pronunciarsi sulla validità delle SCCs e del precedente accordo di trasferimento con gli USA ("il Privacy Shield"), ha stabilito due punti: nel primo, afferma che il Privacy Shield è invalido, ritenendo che le leggi di sorveglianza statunitensi (in particolar modo la Sezione 702 del FISA e l'Executive Order 12333) consentissero alle agenzie di intelligence USA un accesso sproporzionato ai dati dei cittadini dell'Unione Europea, senza garantire loro un rimedio giurisdizionale effettivo. Nella seconda, la Corte afferma la validità delle SCCs con condizioni: il Titolare che le utilizza (data exporter) ha la responsabilità di verificare, caso per caso, se il paese di destinazione offra una protezione sostanzialmente equivalente a quella UE. Nel caso in cui le leggi locali sono in conflitto con le SCCs, l'esportatore deve adottare "misure supplementari" (come la crittografia avanzata) per proteggere i dati o, se impossibile, sospendere il trasferimento. Dunque, la sentenza Schrems II, ha reso estremamente complessi e legalmente rischiosi una gran parte dei trasferimenti di dati verso gli USA (o altri paesi

²¹ NOYB. (2023). *Five Years GDPR: A Look Back at the Biggest Cases*.

²² Commissione Europea. *Decisioni di adeguatezza*.

²³ Corte di Giustizia dell'Unione Europea (CJEU). (2020). *Sentenza nella Causa C-311/18, Data Protection Commissioner c. Facebook Ireland Ltd e Maximillian Schrems ("Schrems II")*.

privi di adeguatezza), imponendo ai Titolari l'obbligo di condurre complesse analisi del rischio chiamate Transfer Impact Assessment (TIA)²⁴. Sebbene nel 2023 sia entrato in vigore un nuovo accordo con gli USA (l'EU-US Data Privacy Framework), la sua tenuta legale resta oggetto di nuove sfide legali da parte dello stesso Schrems²⁵.

2.4 Criticità e dibattiti

Nonostante il suo status di “gold standard” globale, il GDPR, sin dalla sua entrata, è stato oggetto di numerosi dibattiti e critiche significative. Il tentativo ambizioso di bilanciare diritti fondamentali, mercato unico e innovazione tecnologica ha generato tensioni strutturali che ne hanno complicato e ne complicano la messa in atto. Una delle critiche più persistenti si riferisce alla complessità burocratica e ai costi di compliance. L'approccio basato sull'Accountability (Art. 5.2), seppur robusto da un punto di vista concettuale, si traduce in una mole di documenti e procedure che può risultare sproporzionata. Se le Big Tech dispongono di risorse legali e tecniche per gestire questa complessità, per le Piccole e Medie Imprese (PMI) e le startup, il GDPR ha rappresentato un grande ostacolo. La mancanza di risorse, la difficoltà nell'interpretare norme complesse e il timore di sanzioni drammatiche hanno generato, in alcuni casi, un “chilling effect” sull'innovazione e sulla concorrenza²⁶. Numerosi critici sostengono che, in maniera paradossale, il GDPR abbia finito per rafforzare la posizione dominante di alcuni grandi protagonisti nel settore dei dati (come Google o Meta), i quali non fanno fatica a permettersi interi dipartimenti dedicati alla gestione della compliance e che usano la loro interpretazione della norma come scudo. Al contrario, le PMI e le startup faticano a lanciare nuovi servizi data-driven²⁷. In merito alla questione, la Commissione Europea, nei suoi rapporti di valutazione del Regolamento (2020), ha riconosciuto la necessità di supportare maggiormente le PMI²⁸. Nel dibattito sull'efficacia e sulla “proporzionalità” del GDPR, trova spazio quella che può essere considerata la maggiore tensione dei nostri giorni: il GDPR si fonda su un modello di trattamento dati “tradizionale”, che prevede una finalità chiara e un set di dati minimizzato, ed entra in collisione con la logica dei Big Data e del Machine Learning (AI). I principi di limitazione delle finalità (Art. 5.1.b) e di minimizzazione dei dati (Art. 5.1.c.) sono problematici nello sviluppo di applicazioni di intelligenza artificiale. Un modello deep learning richiede, per sua natura, l'addestramento su dataset più ampi e variegati possibile. Spesso, le correlazioni più utili e inaspettate emergono proprio da dati che, a primo impatto, non sembrerebbero “necessari”²⁹. Questo genera un dilemma per gli sviluppatori, i quali si interrogano come sia possibile mettere in atto la massimizzazione e rispettare la minimizzazione prevista dal Regolamento. Inoltre, l'analisi esplorativa dei Big Data non si baserebbe su finalità predeterminate, ma avrebbe come obiettivo la scoperta di nuove finalità. Dunque, appare chiara la perplessità riguardo la definizione di “finalità specifica” mentre l'obiettivo del trattamento si riferisce alla scoperta di nuove. Sebbene il GDPR preveda aperture per la “ricerca scientifica” (Art. 89), l'applicazione di queste concessioni all'innovazione commerciale resta un'area grigia e complessa. Ulteriori perplessità possono essere sottoposte in analisi se si prendono in considerazione alcune delle ultime innovazioni tecnologiche. L'Articolo 22 del GDPR, che garantisce il diritto a non essere sottoposti a decisioni unicamente automatizzate e il diritto di “ottenere l'intervento umano” e “di esprimere la propria opinione”, si

²⁴ European Data Protection Board (EDPB). (2021). *Raccomandazioni 01/2020 sulle misure che integrano gli strumenti di trasferimento a garanzia del rispetto del livello di protezione....* (Versione 2.0).

²⁵ NOYB - European Center for Digital Rights. (2023). *Schrems challenges new EU-US data deal ("Privacy Shield 3.0")*.

²⁶ European Added Value Unit (EPRS). (2020). *The cost of non-Europe in 'The General Data Protection Regulation'*. Parlamento Europeo.

²⁷ Jia, Y., & R. L. R. (2018). *The unintended consequences of the GDPR on digital innovation*. SSRN.

²⁸ Commissione Europea. (2020). *Comunicazione della Commissione [...] Due anni di applicazione del regolamento generale sulla protezione dei dati*. COM(2020) 264 final (pag.10-11)

²⁹ European Data Protection Supervisor (EDPS). (2016). *Opinion 8/2016: EDPS Opinion on the coherent enforcement of fundamental rights in the age of Big Data*.

scontra con la realtà dei modelli AI “Black Box”, come le reti neurali profonde. Per questi modelli, fornire una spiegazione che sia tecnicamente accurata e contemporaneamente comprensibile dal punto di vista umano si configura come una sfida immensa di cui si occupa l’area di ricerca denominata XAI³⁰. A fronteggiare queste lacune, è stato istituito l’AI Act, ma la sua interazione con il GDPR rimane complessa³¹. Per molti critici, la vera antitesi concettuale è rappresentata dalla tecnologia Blockchain per tre principali ragioni: in primo luogo, considerando l’immutabilità dei registri blockchain, non si comprende come sia possibile garantire il diritto di rettifica (Art. 16) o il diritto alla cancellazione/oblio (Art. 17). In secondo luogo, la decentralizzazione che caratterizza una blockchain pubblica e permissionless (come Bitcoin o Ethereum) rende impossibile l’attribuzione della responsabilità³². L’avvento del Metaverso e della “spatial computing” (es. Apple Vision Pro) rappresenta la convergenza di tutte le sfide menzionate: massiccia e continua raccolta di dati biometrici, profilazione emotiva in tempo reale e ambienti digitali persistenti dove la distinzione tra Titolare e Responsabile acquisisce sempre più “fluidità”. Se il GDPR ha avuto il merito storico di definire un robusto impianto di diritti, la sua rigidità e la sua architettura centralizzata (basata sul Titolare) mettono in evidenza numerosi limiti di fronte ad un nascente ecosistema tecnologico decentralizzato, opaco (AI) e immutabile (Blockchain).

Analisi comparativa internazionale

3.1 Sud America

Il Regolamento (UE) 2016/279 non è da considerare un atto legislativo isolato. La sua entrata in vigore ha innescato una riconfigurazione globale delle normative sulla privacy. L’accademia Anu Brandford ha definito questo fenomeno il “Brussel Effect”: la capacità unilaterale dell’UE di “espandere” le proprie normative a livello globale³³. L’UE, sfruttando le caratteristiche del suo vasto mercato unico, “costringe” di fatto le aziende multinazionali e gli Stati terzi ad adottare standard equivalenti ai propri (in questo caso, il GDPR) come condizione preliminare per l’accesso al mercato e per la libera circolazione dei dati. L’ambizione extraterritoriale (Art. 3) e il meccanismo delle Decisioni di Adeguatezza (Art. 45) sono i veicoli legali di questo effetto. Nessuna regione illustra questa dinamica legislativa meglio dell’America Latina. Il Sud America, un continente con forti legami commerciali e culturali con l’Europa, ha recepito l’impatto del GDPR in modo diretto. Sebbene esistessero già quadri giuridici pregressi (in gran parte ispirati al modello spagnolo), il periodo 2016-2020 ha visto una corsa all’aggiornamento, trainata dal bisogno di non essere tagliati fuori dai grandi flussi di dati transatlantici. Il caso del Brasile può essere considerato emblematico. L’adozione della Lei Geral de Proteção de Dados Pessoais (LGPD), Legge n. 13.709/2018³⁴, è stata un processo accelerato: la necessità di allinearsi al GDPR è da ricondurre a scandali interni di violazione di dati e all’urgenza di creare un quadro di certezza giuridica per attrarre investimenti nell’economia digitale. Dal punto di vista strutturale, la LGPD si configura come uno “specchio” del GDPR. Adotta i medesimi principi fondamentali (Art. 6), tra cui finalità, necessità, trasparenza e accountability (chiamata

³⁰ Goodman, B., & Flaxman, S. (2017). *European Union regulations on algorithmic decision-making and a 'right to explanation'*. AI Magazine, 38(3), 50-57.

³¹ Parlamento europeo e Consiglio. (2024). *Regolamento [...] che stabilisce regole armonizzate sull'intelligenza artificiale (Legge sull'intelligenza artificiale)*.

³² Finck, M. (2018). *Blockchain and the General Data Protection Regulation: Can decentralized technologies be squared with European data protection law?*. European Parliament Policy Department for Citizens' Rights and Constitutional Affairs.

³³ Bradford, A. (2020). *The Brussels Effect: How the European Union Rules the World*. Oxford University Press.

³⁴ Presidência da República (Brasile). (2018). *Lei N° 13.709, de 14 de Agosto de 2018 (Lei Geral de Proteção de Dados Pessoais - LGPD)*.

responsabilização). Definisce i ruoli centrali di Controlador (Titolare) e Operador (Responsabile) in maniera quasi identica all'Articolo 4 del GDPR. I diritti degli interessati (chiamati "titulares") nell'Art. 18 includono accesso, rettifica, cancellazione, opposizione e il fondamentale diritto alla portabilità (Art. 18.V). Grazie alla LGPD, viene istituita l'Autoridade Nacional de Proteção de Dados (ANPD)³⁵ dopo un'intensa battaglia politica. Nel 2018, l'allora Presidente Temer votò a favore della sua creazione e, successivamente, il Presidente Bolsonaro la istituì come organo della Presidenza, minandone l'indipendenza (requisito fondamentale per l'adequatezza UE). Soltanto nel 2022, la sua natura è stata trasformata in "autarchia di regime speciale", garantendole l'autonomia formale richiesta dal modello europeo. Nonostante l'impianto brasiliano sia molto legato a quello europeo, esistono alcune divergenze sostanziali. Nell'Articolo 7 della LGPD, vengono elencate dieci basi giuridiche, contro le sei del GDPR. La differenza più significativa risiede nell'Art.7.X, che legalizza il trattamento per la "protezione del credito". Questa base rappresenta una concessione diretta al settore bancario e finanziario brasiliano, risultando essenziale per i sistemi di credit scoring e portando con sé un evidente sbilanciamento. Osservando le Sanzioni (Art. 52), il potere deterrente della LGPD rimane notevolmente inferiore rispetto al GDPR. La sanzione pecuniaria massima è "fino al 2% del fatturato [...] in Brasile [...] limitata nel totale a 50 milioni di Real" (circa 8-9 milioni di euro), mentre il GDPR prevede il 4% del fatturato mondiale senza tetto fisso. Questa limitazione nazionale e il tetto fisso rendono, di sicuro, la LGPD molto meno temibili per le grandi multinazionali. Infine, la LGPD prevede un meccanismo di adeguatezza simile, ma è generalmente percepita come più flessibile sui trasferimenti, non avendo alle spalle una sentenza di corte dirompente e restrittiva come la "Shrems II". Rimanendo sul concetto di adeguatezza, l'Argentina rappresenta un caso unico di "legacy adequacy". In maniera pionieristica, adottò la Ley de Protección de los Datos Personales (Legge 25.326) nel 2000³⁶ e questo le valse una Decisione di Adeguatezza dalla Commissione Europea nel 2003 (Decisione 2003/490/CE), basata sulla Direttiva 95/46/CE³⁷. Questo status, cruciale per l'industria argentina dei servizi (es. sviluppo software), non gode più del "privilegio" ottenuto. Il GDPR, ai sensi dell'Articolo 45, paragrafo 9, impone alla commissione di riesaminare periodicamente le decisioni di adeguatezza preesistenti per assicurare che il livello di protezione rimanga "sostanzialmente equivalente" a quello (molto più elevato) del GDPR. La legge 25.326 risulta carente rispetto ai nuovi standard, in quanto non precede i diritti alla portabilità o alla limitazione, non include i concetti di Privacy by Design e Default, non impone le Valutazioni di Impatto (DPIA), non obbliga alla notifica dei data breach (violazione dati) e possiede un regime sanzionatorio obsoleto, con multe irrisorie caratterizzate da importi simbolici. Per evitare la revoca dell'adequatezza, l'Argentina è protagonista di un processo di riforma forzata. L'autorità di controllo, l'Agencia de Acceso a la Información Pública (AAIP), ha presentato un nuovo progetto di legge che è un quasi totale allineamento al GDPR³⁸. Il progetto introduce l'ambito di applicazione extraterritoriale, i principi di accountability e minimizzazione, il legittimo interesse come base giuridica, le DPIA, la figura del DPO (Delegado de Protección de Datos) e sanzioni calcolate in unità mobili collegate ai ricavi, ricalcando, così, il modello europeo per pura necessità economica. Differentemente dall'Argentina, la Colombia possiede un quadro giuridico già avanzato, basato sulla legge 1581 del 2012, che regola il trattamento dei dati personali, e sulla legge 1266 del 2008, dedicata ai dati finanziari e relativi al credito (Habeas Data). La sua autorità, Superintendencia de Industria y Comercio (SIC), è una delle più attive e più sanzionatorie della regione per via dell'influenza delle linee guida dell'EDPB europeo³⁹.

³⁵ Autoridade Nacional de Proteção de Dados (ANPD). *Sito Ufficiale*.

³⁶ Ministerio de Justicia y Derechos Humanos (Argentina). (2000). *Ley 25.326 - Protección de los Datos Personales*.

³⁷ Commissione Europea. (2003). *Decisione 2003/490/CE [...] relativa all'adeguata protezione dei dati personali in Argentina*.

³⁸ Agencia de Acceso a la Información Pública (AAIP) (Argentina). *Proyecto de Ley de Protección de Datos Personales*.

³⁹ Superintendencia de Industria y Comercio (SIC) (Colombia). *Sito Ufficiale - Protección de Datos*.

3.2 India – Digital Personal Data Protection Act (DPDP, 2023)

Se i casi dell'America Latina illustrano la potente attrattività del “Brussel Effect”, l'India rappresenta, invece, un modello di “sovranità digitale” che, pur mantenendo connessione con i principi europei, si inserisce in un percorso autonomo, influenzato da priorità geopolitiche, economiche e dinamiche costituzionali interne. L'India non può essere considerata un “rule-taker” come l'Argentina o un semplice “adapter” come il Brasile, ma più un “rule-maker” con l'obiettivo di bilanciare la protezione dei cittadini con le coraggiose ambizioni del suo programma “Digital India” e il consolidamento del controllo statale⁴⁰. A differenza dell'Unione Europea, la spinta legislativa indiana non è sorta da obblighi di mercato, ma da un'intensa ed epocale battaglia costituzionale. La svolta è avvenuta con la storica sentenza della Corte Suprema “K.S. Puttaswamy vs Union of India” del 2017⁴¹. In questo caso, la Corte ha dichiarato all'unanimità che la privacy è un diritto fondamentale, intrinsecamente protetto dall'Articolo 21 della Costituzione indiana (“Diritto alla vita e alla libertà personale”). La sentenza Puttaswamy ha, di fatto, obbligato costituzionalmente il governo indiano a legiferare in merito alla protezione di questo diritto. Dopo un lungo e travagliato processo legislativo, durato oltre sei anni e caratterizzato da molteplici bozze, il Parlamento indiano ha approvato il Digital Personal Data Protection Act (DPDP Act) nell'agosto del 2023⁴². Il risultato è un testo che si discosta deliberatamente dalla complessità dell'architettura del GDPR, adottando un approccio basato su principi che, dopo accurata osservazione, si possono definire in gran parte “business-friendly” e, allo stesso tempo, “State-centric”. L'architettura del DPDP Act introduce una nuova terminologia che segnala fin da subito una distanza concettuale dal GDPR: il Titolare (Data Controller) diventa il “Data Fiduciary” (Fiduciario dei Dati) e l'Interessato (Data Subject) viene definito “Data Principal”. L'impianto si mantiene saldo su tre pilastri chiave: a differenza del GDPR, che si riferisce a dati registrati in qualsiasi formato, il DPDP Act limita il suo ambito di applicazione esclusivamente al trattamento dei dati personali digitali. I dati non digitali sono inclusi soltanto nel caso in cui vengono successivamente digitalizzati (Sezione 4). Come si evince dalla Sezione 6, nel DPDP Act, il consenso rimane un pilastro (come nel GDPR), ma viene introdotto il concetto innovativo di “Consent Manager” (Sezione 6.7). Il Consent Manager, soggetto a registrazione presso l'Autorità, rappresenta una figura intermedia attraverso cui un Data Principal può dare, gestire, revisionare e revocare il proprio consenso in modo centralizzato. A differenza del GDPR, che si fonda sulla base giuridica del legittimo interesse, il DPDP Act introduce una vasta categoria di “Legitimate Uses” (Usi Legittimi) per i quali il consenso è “deemed” (ritenuto) e non è necessario richiederlo. Dunque, questo si applica a scenari ampi come l'adempimento delle sentenze, le emergenze mediche, la sicurezza nazionale e scopi professionali, legati all'impiego, lasciando un margine di interpretazione molto ampio⁴³. In altre parole, invece di fornire alle aziende uno strumento flessibile (e a volte rischioso) come il “legittimo interesse”, la Sezione 7 afferma che, per un elenco specifico di finalità, il consenso dell'individuo non è necessario perché è “ritenuto” (deemed), dato per scontato dalla legge. La divergenza più profonda fra DPDP Act e GDPR è rappresentata dalla natura “statocentrica” del sistema indiano. Mentre il modello europeo, influenzato dalla sentenza Shrems II e dallo scandalo PRISM, fu elaborato con l'intento di proteggere l'identità individuale sia da terzi che dalla possibile sorveglianza statale, il DPDP Act opera in maniera opposta. La sezione 35 dell'atto (nota precedentemente come Sezione 36 nelle bozze) conferisce al Governo Centrale il potere quasi illimitato di esentare “qualsiasi agenzia dello stato” (Instrumentalities of the State) dall'applicazione della legge nella sua interezza, per motivazioni che possono riguardare la “sicurezza dello Stato”, la “sovranità e

⁴⁰ Rajagopalan, R., & S. B. P. (2023). *India's Digital Sovereignty: The Data Protection Bill in Context*. Observer Research Foundation (ORF).

⁴¹ K.S. Puttaswamy (Retd.) and Ors. vs. Union of India and Ors. (2017) 10 SCC 1.

⁴² The Government of India (2023). *The Digital Personal Data Protection Act, 2023 (No. 22 of 2023)*. The Gazette of India.

⁴³ Internet Freedom Foundation (IFF) (2023). *The DPDP Act, 2023: An analysis of 'deemed consent'*.

integrità dell'India" o il "mantenimento dell'ordine pubblico"⁴⁴. Questa "esenzione governativa" risulta molto più ampia delle deroghe per la sicurezza nazionale previste dal GDPR (le quali sono soggette al controllo della Corte di Giustizia UE e al principio di proporzionalità). Di fatto, pone le basi per un "regime duale": da un lato il privato e dall'altro il pubblico. Tale impostazione è rafforzata dalla struttura dell'autorità di controllo. A differenza delle Autorità Garanti europee, la cui indipendenza è un requisito costituzionale (Art. 8 della Carta UE), il Data Protection Board of India (DPBI) è un organo i cui membri sono nominati direttamente dal governo centrale (Sezione 19). Ciò solleva dubbi significativi sulla imparzialità, specialmente in casi che coinvolgono agenzie governative⁴⁵. In merito alla questione dei trasferimenti internazionali (Sezione 16), l'India abbandona il complesso sistema di adeguatezza e SCCs del GDPR. Infatti, adotta un approccio definito "default-permit" (o "whitelist"), per cui il Governo Centrale ha la possibilità, con una semplice notifica, di identificare paesi o territori ai quali i trasferimenti dati sono permessi liberamente, senza la necessità per il Data Fiduciary di elaborare valutazioni di impatto sul trasferimento⁴⁶. Infine, sebbene il regime sanzionatorio (Sezione 33) preveda multe significative per i Fiduciari (fino a 250 Crore di rupie, l'equivalente di circa 30 milioni di euro), il DPDP Act introduce un elemento assente nel GDPR, ovvero, le sanzioni per i Data Principals (Sezione 37), le quali riguardano le violazioni dei doveri elencati nella Sezione 15. Tra gli obblighi del Data Principal troviamo l'obbligo di rispettare le disposizioni di tutte le leggi applicabili mentre esercita i diritti previsti dall'Atto, deve assicurarsi di non impersonare un altro individuo mentre fornisce i propri dati personali per uno scopo specifico, assicurarsi di non sopprimere alcuna informazione materiale mentre fornisce i propri dati personali per qualsiasi documento, identificatore unico, prova di identità o prova di indirizzo emessi dallo stato, assicurarsi di non registrare un reclamo o una lamentela falsa o futile presso un Data Fiduciary o il DPBI e fornire solo informazioni che siano "verificabili e autentiche" quando esercita il diritto alla correzione o alla cancellazione. Dunque, appare chiara la differenza con il GDPR, in quanto non vengono presentati soltanto i diritti degli interessati ma anche doveri e le sanzioni connesse alla loro violazione. In sintesi, il DPDP Act 2023 indiano, non può essere considerato un "discepolo" del GDPR, ma più un rivale strategico. È un modello che ha come priorità la sovranità digitale nazionale, la flessibilità per l'economia digitale e, soprattutto, attribuisce potere di sorveglianza allo stato. L'antropocentrismo del GDPR viene messo da parte in favore di un modello "Stato-centrico", che pone la privacy come un diritto dell'individuo nei confronti delle imprese private, senza però fornire uno scudo efficace contro il potere governativo.

3.3 Giappone – Act on the Protection of Personal Information (APPI)

Il caso del Giappone si discosta nettamente sia dal modello "adapter" brasiliano che da quello "sovranista" dell'India. In virtù del suo status nell'economia globale, il Giappone si pone come un "rule-shaper" a pieno titolo, cercando la convergenza con l'Unione Europea non per influenza del "Brussel Effect", ma per una precisa strategia geopolitica ed economica: creare un blocco di democrazie digitali basato sulla fiducia e sulla collaborazione, in contrapposizione ad altri modelli presentati⁴⁷. Questa strategia, nota come "Data Free Flow with Trust" (DFFT), è stata promossa attivamente dal Giappone come tentativo di mediare tra il modello UE, quello statunitense e quello cinese, ponendosi come un ponte normativo⁴⁸. L'evoluzione della legislazione giapponese in merito alla protezione dei dati è

⁴⁴ The Digital Personal Data Protection Act, 2023 (Act No. 22 of 2023). Testo ufficiale della legge pubblicato dal Ministry of Electronics and Information Technology (MeitY).

⁴⁵ Ibid., Sezione 19 ("Establishment of Data Protection Board of India"). (Riferimento alla Sezione 19 dell'Atto citato al punto 42).

⁴⁶ Ibid., Sezione 16 ("Transfer of personal data outside India"). (Riferimento alla Sezione 16 dell'Atto citato al punto 42).

⁴⁷ Commissione Europea, "La Commissione e il Giappone avviano il dialogo per facilitare i flussi di dati" (Comunicato stampa, 2017).

⁴⁸ Center for Strategic and International Studies (CSIS). (2019). "Japan's G20 Leadership on Data Governance".

risultata graduale e pragmatica. Il primo atto legislativo risale al 2003, l'Act on the Protection of Personal Information (APPI), poi modernizzato radicalmente nel 2015. La forma evoluta dell'atto è entrata in vigore nel 2017 e ha istituito per la prima volta un'autorità di controllo centrale e indipendente, la Personal Information Protection Commission (PPC)⁴⁹. Il punto di svolta che ha reso il Giappone protagonista nella definizione delle nuove regole è la cosiddetta "Decisione di Adeguatezza Reciproca" del 23 gennaio 2019⁵⁰. Questo non rappresenta un riconoscimento unilaterale da parte dell'Unione Europea, come quello concesso all'Argentina, ma un vero e proprio "patto" bilaterale: la Commissione Europea ha riconosciuto il Giappone come "adeguato" ai sensi dell'Art. 45 del GDPR, e simultaneamente la PPC giapponese ha riconosciuto l'UE come un sistema "equivalente" ai sensi dell'Art. 28 dell'APPI (ex. Art. 24). Questo ha reso possibile la creazione della più grande area al mondo di libera circolazione dei dati "sicuri"⁵¹. Tuttavia, per il raggiungimento di questo traguardo, non è bastata una semplice somiglianza legislativa, ma sono state necessarie delle "Regole Supplementari" (Supplementary Rules) che le aziende giapponesi devono applicare ai dati provenienti dall'Unione Europea⁵². Queste regole vanno a colmare alcune lacune presenti nei due sistemi su due fronti: in primo luogo, l'APPI possiede una categoria di "dati personali che richiedono particolare attenzione", ma è meno ampia dell'Articolo 9 del GDPR. Le Regole Supplementari obbligano a trattare come "sensibili" tutti i dati definiti tali dal GDPR (es. orientamento sessuale, tipologia di sindacato a cui si è iscritti) che non erano coperti dalla legge giapponese. In secondo luogo, l'APPI risultava più permissivo sui trasferimenti di dati dal Giappone verso un paese terzo (diverso dall'UE). Le Regole Supplementari impongono alle aziende giapponesi l'obbligo di ottenere un consenso specifico aggiuntivo prima di poter ri-trasferire i dati europei. La differenza più interessante, però, risiede nell'approccio all'innovazione. A differenza del GDPR, che mantiene una solida distinzione tra dato pseudonimizzato (ancora personale) e dato anonimo (fuori ambito), l'APPI del 2015 ha introdotto una categoria particolare: l'Informazione Anonimizzata (Tokumei Kakou Jouhou) (Art. 2.6)⁵³. Questo non rappresenta un dato "anonimo" (irriconecibile), ma un dataset che è stato processato secondo standard legali specifici per renderlo difficilmente re-identificabile e che può essere utilizzato e trasferito più liberamente (anche senza consenso), a patto di informare il pubblico. Questo approccio pragmatico e orientato al business mostra in pieno la filosofia giapponese: trovare l'equilibrio necessario ai fini di incentivare l'economia dei dati (Big Data, AI) alleggerendo gli oneri e mantenendo una protezione di base. Dal punto di vista dell'enforcement, la PPC, pur avendo poteri sanzionatori, è risultata storicamente meno aggressiva della controparte europea, optando per un approccio basato sulla guidance e sulla responsabilità reputazionale (elemento fondamentale nella cultura d'azienda giapponese). Tuttavia, le successive riforme del 2020 e 2022 (entrate in vigore rispettivamente nel 2022 e 2023) hanno inasprito in maniera notevole le sanzioni pecuniarie per le imprese. Infatti, sono stati aumentati i massimali e sono stati rafforzati i diritti individuali (es. in caso di data breach), avvicinando l'APPI al modello europeo, anche in virtù del mantenimento della solidità dell'accordo di adeguatezza⁵⁴. In sintesi, il modello giapponese si presenta come un sofisticato ibrido, in quanto converge con il modello UE sui principi fondamentali, sull'indipendenza dell'Autorità di Controllo (PPC) e sulla necessità di mettere in atto tutele forti, come dimostra l'accordo di adeguatezza reciproca. Inoltre, l'APPI mantiene la sua specificità attraverso un approccio pragmatico all'innovazione e una

⁴⁹ Personal Information Protection Commission of Japan (PPC). (2017). "Establishment of the Personal Information Protection Commission and the 2015 Amendments to the APPI".

⁵⁰ Commissione Europea. (2019). "Decisione di esecuzione (UE) 2019/419 della Commissione, del 23 gennaio 2019, relativa all'adeguatezza della protezione dei dati personali in Giappone".

⁵¹ Commissione Europea. (2019). "EU-Japan create the world's largest area of safe data flows"

⁵² Personal Information Protection Commission of Japan (PPC). (2019). "Supplementary Rules under the Act on the Protection of Personal Information for handling personal data transferred from the EU based on an adequacy decision".

⁵³ International Association of Privacy Professionals (IAPP). (2017). "A closer look at Japan's 'anonymously processed information'".

⁵⁴ DLA Piper. (2022). "Japan: Key changes under the amended APPI". *DLA Piper Publications*.

cultura di enforcement che bilancia sanzioni e guidance. Terminata l'analisi dei modelli normativi, dal GDPR ai suoi "specchi" e ai suoi "rivali" globali, è necessario evidenziare quella che può essere definita come la sfida più critica, ovvero, illustrare l'enactment dei modelli proposti. Dunque, nella parte successiva, il focus si sposta sugli strumenti di governance, le metodologie e le tecnologie indispensabili per rendere effettivi i contenuti legislativi dei modelli.

Enactment: approcci, metodologie e tecnologie

4.1 Approcci organizzativi e relativi alla governance

L'analisi comparativa condotta nella parte precedente ha evidenziato come, nonostante le differenze filosofiche e normative, tutti i sistemi giuridici avanzati condividano una sfida comune: l'effettività (l'enactment). Il divario tra norma scritta e la sua applicazione pratica risulta essere il vero banco di prova per la tutela dei diritti nell'economia digitale. Il GDPR, in particolare, ha tentato di colmare questo divario attraverso il principio cardine dell'Accountability, che sposta l'onere della prova sul Titolare. Quest'ultimo non solo deve essere conforme, ma deve anche essere in grado di comprovare la sua conformità (Art. 24). L'Accountability non è un concetto astratto, ma un obbligo che si traduce in una serie di processi e metodologie preventive. Queste ultime non rappresentano soltanto mera "documentazione", ma strumenti di gestione del rischio che impongono una riflessione a priori sull'impatto dell'attività di trattamento. Il principale strumento di governance preventiva introdotto dal GDPR è la Valutazione d'Impatto sulla Protezione dei Dati (DPIA), codificata dall'Articolo 35⁵⁵. La DPIA rappresenta la formalizzazione del "principio di precauzione" applicato ai dati personali. Non è un adempimento di carattere burocratico eseguibile una tantum, ma un processo ciclico che costringe il Titolare a valutare quali siano i rischi prima che questi possano concretizzarsi. L'Articolo 35 la rende obbligatoria solo quando un trattamento, in particolar modo se basato su nuove tecnologie, "può presentare un rischio elevato per i diritti e le libertà delle persone fisiche". I Regolatori nazionali (es. Garante italiano) hanno fornito elenchi di trattamenti che richiedono sempre una DPIA. Il processo di una valutazione d'impatto, come delineato dall'EDPB⁵⁶, si articola in quattro fasi fondamentali⁵⁷: si effettua la Descrizione del trattamento, attraverso la mappatura dei flussi (data lineage), basandosi sulla natura dei dati, le finalità e la base giuridica; si elabora la Valutazione di necessità e proporzionalità, ovvero, si analizza la coerenza tra dati raccolti e le finalità dichiarate (minimizzazione) e della validità della base giuridica (liceità); la fase successiva riguarda la Valutazione dei rischi, nella quale il Titolare ha il compito di identificare le minacce (es. accesso non autorizzato, modifica, data loss) e valutarne la probabilità e la gravità dell'impatto sull'interessato; infine, vengono adottate misure per mitigare il rischio attraverso la definizione di controlli tecnici (es. pseudonimizzazione, crittografia) e organizzativi (es. politica di accesso, formazione) per ridurre il rischio residuo ad una soglia di accettabilità. Se la DPIA rileva un rischio residuo elevato, l'Articolo 36 impone al Titolare l'obbligo di consultazione preventiva dall'Autorità di controllo. La DPIA, quindi, non rappresenta un semplice strumento interno, ma un meccanismo di comunicazione e supervisione regolamentata, incarnando il passaggio da una logica reattiva (es. intervento post-data breach) a una logica "proattiva" basata sul rischio. Se la DPIA resta lo strumento per la valutazione del rischio, la Privacy By Design e by Default è la metodologia ingegneristica e manageriale per evitare il problema dalla sua radice. L'Articolo 25

⁵⁵ European Data Protection Board (EDPB). (2017). "Linee guida concernenti la valutazione di impatto sulla protezione dei dati nonché i criteri per stabilire se un trattamento 'possa presentare un rischio elevato' ai sensi del regolamento 2016/679" (WP 248 rev.01).

⁵⁶ European Data Protection Board (EDPB). (2017). "Linee guida concernenti la valutazione di impatto sulla protezione dei dati nonché i criteri per stabilire se un trattamento 'possa presentare un rischio elevato' ai sensi del regolamento 2016/679" (WP 248 rev.01).

⁵⁷ Citato al punto 56.

del GDPR ha elevato questo concetto, precedentemente teorico, a obbligo legale⁵⁸. Il concetto di Privacy by Design fu sviluppato nel corso degli anni '90 da Ann Cavoukian, allora Garante della Privacy dell'Ontario, e si basa su Sette Principi Fondamentali⁵⁹. In sostanza, afferma che la privacy, come abbiamo detto in una delle sezioni precedenti, non può essere un plus da aggiungere alla fine del processo di sviluppo software o di creazione di un servizio, ma deve essere integrata "by Design" ("fin dalla progettazione") come componente fondamentale del sistema allo stesso livello della sicurezza o della funzionalità. Da un punto di vista operativo, ciò implica che gli ingegneri e i product manager devono, ad esempio, minimizzare i dati raccolti a livello di architettura nel database, implementare tecniche di pseudonimizzazione, costruire sistemi che permettano l'esercizio dei diritti (es. portabilità, cancellazione ecc.) in modo automatizzato e non manuale. La Privacy by Default è la sua applicazione pratica rivolta all'utente. Impone che qualsiasi impostazione di un servizio o prodotto debba essere, al momento della release al pubblico, quella più protettiva della privacy. In altre parole, l'utente non deve essere costretto ad interfacciarsi con menù complessi e ostici per limitare (se lo desidera) la condivisione dei propri dati. Al contrario, deve essere l'utente stesso a compiere un'azione consapevole per aumentare la condivisione. Questo principio rappresenta l'esatto opposto della logica precedente al GDPR (dei moduli pre-spuntati e dei profili social impostati come "pubblici" al momento dell'iscrizione). L'Articolo 25, dunque, trasferisce la responsabilità della protezione dal singolo utente, che spesso è privo di competenze tecniche, al Titolare, imponendogli di progettare sistemi che si possono definire senza fatica "virtuosi". Gli obblighi presentati fino a questo momento richiedono una struttura di governance permanente, supportata da framework standardizzati che permettono la gestione, la misurazione e l'analisi della conformità. Questi framework pongono in relazione il mondo legale-compliance con quello dello sviluppo IT e della gestione dati. Si possono rilevare tre framework standard che svolgono questo compito: il primo è l'ISO/IEC 27701:2019, lo standard di riferimento per la gestione della privacy, il quale è un'estensione diretta del celebre ISO/IEC 27001 (relativo ai Sistemi di Gestione della Sicurezza delle Informazioni, ISMS). L'ISO/IEC 27701:2019 crea un Privacy Information Management System (PIMS)⁶⁰ e possiede un duplice vantaggio: mappa i requisiti di privacy sui controlli di sicurezza già noti e la sua operatività è certificabile, portando, quindi, le aziende ad avere maggiore efficacia per la dimostrazione di Accountability ai sensi dell'Articolo 5.2. Per la gestione del rischio, il National Institute of Standards and Technology ha sviluppato il suo Privacy Framework (NIST Privacy Framework)⁶¹. A differenza della ISO, non è uno standard di certificazione, ma più una "guida" dotata di flessibilità. È strutturato secondo le cinque funzioni del NIST Cybersecurity Framework, che include Identify, Govern, Control, Communicate e Protect. La sua forza risiede nel suo intrinseco pragmatismo, in quanto aiuta le organizzazioni a comunicare sul rischio di privacy, a definire gli "stati target" e le priorità degli interventi. Infine, occorre menzionare il DAMA-DMBOK (Data Management Body of Knowledge), il quale non rappresenta un framework relativo alla privacy, ma una sorta di framework di guida generale della Data Governance⁶². Il DAMBOK di Dama International riguarda tutte le aree della gestione dati (dall'architettura alla qualità, metadata, warehousing ecc.). La sua importanza risiede nella capacità di dimostrare che un'efficace protezione dei dati è impossibile senza una solida e matura governance dei dati. In altre parole, un'organizzazione non può effettuare operazioni di minimizzazione di dati (Art. 5.1) o rispettare i limiti di conservazione

⁵⁸ Regolamento (UE) 2016/679 (GDPR). Articolo 25 – "Protezione dei dati fin dalla progettazione e protezione dei dati per impostazione predefinita". *EUR-Lex*.

⁵⁹ Cavoukian, A. (2011). "Privacy by Design: The 7 Foundational Principles". *Information and Privacy Commissioner of Ontario, Canada*.

⁶⁰ International Organization for Standardization (ISO). (2019). "ISO/IEC 27701:2019 - Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines".

⁶¹ National Institute of Standards and Technology (NIST). (2020). "NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management (Version 1.0)".

⁶² DAMA International. (2017). "DAMA-DMBOK: Data Management Body of Knowledge (2nd Edition)". *DAMA International*.

se non ha prima implementato processi robusti per sapere la natura dei dati in possesso, l'allocazione, i permessi di accesso e quale sia il loro ciclo di vita. Dunque, l'approccio organizzativo richiesto nell'era del GDPR trasforma la privacy da un problema puramente legale ad una disciplina che mescola management e ingegneri. La DPIA agisce come strumento di valutazione del rischio, la Privacy by Design come metodologia di progettazione e i framework (come ISO, NIST e DAMA) forniscono l'impalcatura gestionale per rendere questi principi operativi e misurabili.

4.2 Strumenti tecnologici per l'attuazione del GDPR

Se gli approcci organizzativi e i framework di governance costituiscono l'impalcatura strategica dell'Accountability, l'effettiva implementazione dei principi del GDPR, in particolar modo, la Minimizzazione (Art. 5.1.c), l'Integrità e Riservatezza (Art. 5.1f) e la Privacy by Design (Art. 25), è un compito di natura tecnica. L'evoluzione tecnologica non è soltanto la "causa" delle sfide alla privacy, ma risulta essere anche la fonte delle soluzioni più efficaci. Questo campo è noto come Privacy-Enhancing Technologies (PETs), un insieme di strumenti progettati per rafforzare la protezione dei dati e minimizzare la loro esposizione⁶³. La prima e più importante strategia di Privacy by Design è ridurre il rischio all'origine, operando sull'identificabilità del dato. In merito a ciò, il GDPR distingue nettamente il processo di Pseudonimizzazione (definito nell'Art. 4.5) da quello di Anonimizzazione. Il primo menzionato rappresenta "il trattamento dei dati personali in modo tale che i dati non possano più essere attribuiti a un interessato specifico senza l'utilizzo di informazioni aggiuntive". Esempi comuni di Pseudonimizzazione includono il tokenization o l'hashing di un identificativo. È esplicitamente incoraggiato dal GDPR (Art. 25 e Art. 32) come misura di sicurezza. Tuttavia, è importante sottolineare che i dati pseudonimizzati rimangono dati personali, poiché si tratta di un processo caratterizzato da reversibilità (il Titolare detiene la "chiave" di re-identificazione). L'Anonimizzazione, invece, è un processo di rimozione irreversibile degli identificatori, rendendo, quindi, impossibile reidentificare l'interessato. Infatti, quando un dataset è veramente anonimo, esso esce dal campo di applicazione del GDPR. Mentre la pseudonimizzazione è considerata una misura di sicurezza, l'anonimizzazione è una strategia di minimizzazione drastica. Tuttavia, la "vera" anonimizzazione rimane tecnicamente complessa, in quanto tecniche semplici come la rimozione di nomi e codici fiscali si sono rivelate fallimentari, come dimostrato da Latanya Sweeney in merito alla celebre reidentificazione dei dati sanitari del governatore del Massachusetts negli anni '90⁶⁴. Per questo motivo, sono state elaborate tecniche statistiche molto più avanzate come la k-Anonymity e la Differential Privacy. La k-Anonymity, proposta dalla stessa Sweeney, impone che ogni record in un dataset pubblicato sia indistinguibile da almeno k-1 altri record. Si ottiene attraverso la generalizzazione (es. "età 22" che diventa "età 20-30") e la soppressione di attributi. Sebbene sia possibile dedurre la sua utilità, la k-Anonymity rimane vulnerabile ad "attacchi ad omogeneità" (es. tutti i k record hanno la stessa malattia, la privacy è violata)⁶⁵. La Differential Privacy è considerata lo standard principale moderno. Rispetto alla tecnica precedente, l'approccio è diverso, in quanto non mira a "pulire" il dataset, ma protegge il risultato delle query in riferimento a esso. La DP aggiunge una quantità (calibrata) di "rumore statistico" a ogni risposta, in modo tale che il risultato della query sia statisticamente (quasi) identico sia che i dati di un singolo individuo si trovino nel dataset, sia che non siano inclusi⁶⁶. Dunque, questo fornisce una garanzia matematica contro la reidentificazione e, proprio per questo, è utilizzata da aziende come

⁶³ ENISA (European Union Agency for Cybersecurity). (2021). "Privacy Enhancing Technologies - An overview".

⁶⁴ Sweeney, L. (2002). "k-Anonymity: A Model for Protecting Privacy". *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*.

⁶⁵ Samarati, P. & Sweeney, L. (1998). "Protecting privacy when disclosing information: k-anonymity and its enforcement through generalization and suppression".

⁶⁶ Dwork, C., & Roth, A. (2014). "The Algorithmic Foundations of Differential Privacy". *Foundations and Trends in Theoretical Computer Science*.

Apple, Google e dallo US Census Bureau⁶⁷. Il principio di “Integrità e Riservatezza” (Art. 5.1.f) e l’Articolo 32 impongono al titolare di proteggere i dati da accessi non autorizzati. Questo si traduce in sistemi di Identity and Access Management (IAM). Tra i sistemi troviamo l’OAuth 2.0 e OpenID Connect (OIDC), ovvero, i protocolli standard dell’odierno web per la “delega dell’autorizzazione”. In pratica, quando una app chiede il permesso di “Accedere con Google” o “Accedere con Facebook”, sta usando OAuth 2.0. Il valore di quest’ultimo in merito alla privacy è enorme, in quanto permette a un utente di concedere ad un’applicazione terza un accesso limitato e specifico (“solo il nome e l’email”) ai propri dati detenuti da un altro titolare, senza mai condividere la propria password d’accesso. Viene considerata, infatti, un’implementazione tecnica del consenso specifico e granulare (Art.7) e della minimizzazione dell’accesso⁶⁸. Per la complessità degli ambienti cloud e ibridi si può menzionare Zero Trust Architecture (ZTA), la quale si basa sul motto “Never trust, always verify”⁶⁹. Come definito dal NIST nel suo documento SP 800-207, una ZTA tratta ogni richiesta d’accesso come se provenisse da una rete ostile. Ogni utente, dispositivo e applicazione deve essere autenticato e autorizzato ad ogni singola richiesta. Secondo il GDPR, questo approccio garantisce che soltanto chi è strettamente autorizzato possa accedere ai dati personali, riducendo, così, la possibilità di attacco⁷⁰. Infine, il Self-Sovereign Identity (SSI) si occupa di spostare il controllo dall’azienda all’individuo, incarnando l’autodeterminazione informativa. Invece di possedere identità frammentate in “silos”, l’utente possiede le proprie “credenziali verificabili” (Verifiable Credentials, VCs) in un wallet digitale personale. Dunque, l’utente può dimostrare un attributo (es. Maggiore età) a terzi, senza dover rivelare il dato alla base dell’affermazione (la data di nascita esatta). Questo modello, verificato dal W3C, può essere considerato la massima espressione di minimizzazione e controllo dell’interessato⁷¹. Come discusso nella parte 2.4, la tecnologia blockchain offre opportunità e, allo stesso tempo, presenta criticità uniche. Una blockchain (specie se permissioned o privata) offre una trasparenza e un’integrità notevoli. Grazie agli smart contract, è possibile creare un registro invariabile e perfettamente “auditable” della gestione del consenso, includendo chi ha fornito il consenso, la data, per quali finalità e la data di revoca (se presente). Questo aspetto lo rende perfettamente conforme all’onere di dimostrare il consenso (Art. 7.1). Tuttavia, l’immutabilità della blockchain si scontra con i diritti dell’interessato. In una blockchain pubblica, come Bitcoin, i dati scritti non possono essere mai eliminati e, dunque, questo rende impossibile esercitare il Diritto alla Cancellazione (Oblio) (Art. 17) e il Diritto di Rettifica (Art. 16). Inoltre, la natura decentralizzata rende quasi impossibile identificare il Titolare del Trattamento, facendo crollare l’intero impianto di responsabilità del GDPR⁷². In riferimento al conflitto tra Big Data, AI e Minimizzazione, sono state sviluppate una serie di tecnologie volte alla risoluzione del problema. Il tradizionale training del machine learning richiede di centralizzare una massiccia quantità di dati grezzi in un unico “data lake”, creando un enorme rischio di privacy. Uno dei paradigmi che si occupa di mitigare il problema è l’Edge Computing, il quale sposta le attività di elaborazione (computing) dal cloud centrale alla periferia di rete, ovvero, sul dispositivo dell’utente (edge). Il Federated Learning è l’applicazione del paradigma precedente al machine learning. Il processo di Federated Learning si può esporre in quattro fasi, nelle quali un modello AI generico viene inviato ai dispositivi degli utenti (es. gli smartphone), l’addestramento avviene localmente su ogni dispositivo, utilizzando i dati personali che non lasciano mai lo smartphone (es. abitudini di digitazione). Successivamente, soltanto gli aggiornamenti del modello (aggregati e anonimizzati) vengono inviati al server centrale, il quale raggruppa gli aggiornamenti per migliorare il modello globale che verrà ridistribuito⁷³. Dunque, questo

⁶⁷ DifferentialPrivacy.org. (s.d.). "Who uses differential privacy?".

⁶⁸ IETF (Internet Engineering Task Force). (2012). "RFC 6749: The OAuth 2.0 Authorization Framework".

⁶⁹ Zero Trust Architecture: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>

⁷⁰ NIST (National Institute of Standards and Technology). (2020). "SP 800-207: Zero Trust Architecture".

⁷¹ W3C (World Wide Web Consortium). (2022). "Verifiable Credentials Data Model v1.1".

⁷² Finck, M. (2018). "Blockchains and Data Protection in the European Union". *European Data Protection Law Review*.

⁷³ Google AI Blog. (2017). "Federated Learning: Collaborative Machine Learning without Centralized Training Data".

risulta essere l'implementazione tecnologica più pura della Privacy by Design e della Minimizzazione, in quanto permette alle aziende di ottenere i benefici dell'addestramento su larga scala senza mai raccogliere, centralizzare o processare dati personali (e grezzi) degli utenti. È importante sottolineare, tuttavia, che l'adozione di queste PETs non è una garanzia definitiva di conformità, ma necessita di verifiche costanti. La sezione successiva prenderà in esame gli strumenti di monitoraggio e auditing necessari a comprovare l'efficacia delle misure presentate.

4.3 Monitoraggio e auditing della compliance

L'implementazione di robusti framework organizzativi e di Privacy-Enhancing Technologies non è sufficiente a soddisfare il principio cardine dell'Accountability, in quanto, quest'ultimo, richiede al titolare di essere in grado di comprovare il rispetto dei principi. Dunque, il monitoraggio e l'auditing non sono misure opzionali, ma la componente probatoria e ciclica della compliance. Il processo si articola su un piano interno, nel quale si inseriscono la mappatura e la verifica, e un piano esterno, nel quale avviene il controllo delle autorità competenti. Il Registro delle attività di trattamento (Art. 30, GDPR) è alla base di qualsiasi attività di audit⁷⁴. Il Registro rappresenta la mappa fondamentale della governance dei dati, il documento che risponde alle domande più essenziali: quali sono i dati trattati, la motivazione (finalità e base giuridica), il periodo di tempo di conservazione e i destinatari dei trasferimenti. Tuttavia, una mappa statica diviene inutile se l'ambiente IT muta continuamente. Proprio per fronteggiare il cambiamento, entra in gioco il Data Lineage, il quale è il processo (molto spesso automatizzato) che traccia l'intero ciclo di vita del dato⁷⁵. Possedere un sistema di Data Lineage automatizzato rappresenta il prerequisito tecnico per attuare un auditing efficace, in quanto permette di verificare la Minimizzazione, monitorare gli Accessi (Art. 32) e automatizzare la Compliance⁷⁶. Come analizzato nella sezione precedente, le tecnologie di machine learning (in particolar modo i modelli "Black Box"), rappresentano la sfida più grande per l'audit. Se un Titolare utilizza un modello AI per prendere decisioni automatizzate, come l'assunzione di personale o la concessione di credito, sorge una perplessità riguardo la spiegabilità della decisione del modello. Il GDPR, con gli Articoli 13, 14 e 15, obbliga il titolare a fornire "informazioni significative sulla logica utilizzata" nei processi decisionali automatizzati e l'Articolo 22 garantisce, come è stato menzionato nelle sezioni precedenti, il diritto di "ottenere l'intervento umano"⁷⁷. Appare ovvio che questi diritti siano impossibili da garantire senza l'interpretabilità. L'area di ricerca dell'Explainable AI (XAI), attraverso un insieme di tecniche, mira a rendere i modelli più trasparenti. Le tecniche adottate non spiegano il funzionamento del modello nella sua interezza (spesso impossibile per grandi modelli), ma illustrano la ragione per cui il modello ha preso una specifica decisione⁷⁸. Tra le più note figurano LIME (Local Interpretable Model-agnostic Explanations) e SHAP (Shapley Additive exPlanations). La prima è una tecnica che spiega una decisione complessa con la creazione di un modello di piccole dimensioni interpretabile, il quale approssima il comportamento della black box esclusivamente presso quella specifica decisione⁷⁹. SHAP, invece, è un metodo che assegna a ciascuna feature un indice di importanza che ne quantifica il

⁷⁴ Regolamento (UE) 2016/679 (GDPR). Articolo 30 – "Registri delle attività di trattamento".

⁷⁵ DAMA International. (2017). "DAMA-DMBOK: Data Management Body of Knowledge (2nd Edition)". Capitolo su "Data Governance" e "Metadata Management".

⁷⁶ Gartner. (s.d.). "Data Lineage". *Gartner Glossary*.

⁷⁷ Regolamento (UE) 2016/679 (GDPR). Articolo 22 – "Processo decisionale automatizzato relativo alle persone fisiche, compresa la profilazione".

⁷⁸ DARPA (Defense Advanced Research Projects Agency). "Explainable Artificial Intelligence (XAI)". *DARPA Programs*.

⁷⁹ Ribeiro, M. T., Singh, S., & Guestrin, C. (2016). "Why Should I Trust You?": Explaining the Predictions of Any Classifier". *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*.

contribuito alla decisione finale⁸⁰. Adottare gli strumenti XAI sta diventando man mano un requisito legale per poter dimostrare che i propri modelli AI non operino effettuando discriminazioni e non violino i diritti degli interessati. Questa esigenza è diventata il fulcro dell'AI Act dell'UE, il quale prevede obblighi di trasparenza e specifici audit per sistemi AI ad "alto rischio", completando, così, le tutele previste dal GDPR⁸¹. L'auditing della compliance non si limita ad essere un esercizio puramente interno. L'ultimo livello di monitoraggio spetta alle Autorità Garanti per la Protezione dei Dati (DPA). L'Articolo 58 del GDPR conferisce alle DPA poteri di indagine notevoli, come quello di "ottenere l'accesso a tutti i dati personali" e "condurre un audit sulla protezione dei dati" presso i locali del Titolare⁸². Tuttavia, come evidenziato dalla sentenza Shrems II e dalla natura delle Big Tech, il carattere transnazionale dei flussi di dati, indebolisce il potere di una singola autorità nazionale. Per questo motivo, il GDPR ha creato strumenti di cooperazione internazionale, sia per l'audit che per l'enforcement. Come visto nella sezione 2.3, l'EDPB non è soltanto un organo di consultazione, ma la piattaforma di cooperazione che permette alle DPA di condurre indagini in collaborazione e di emettere decisioni uniche sui casi transnazionali⁸³. Ovviamente, l'esigenza di cooperazione oltrepassa i confini dell'Unione Europea. La Global Privacy Assembly (GPA) rappresenta il forum globale che riunisce oltre 130 autorità di protezione dati, incluse la PPC giapponese e l'ANPD brasiliana. Nonostante le sue risoluzioni non siano (ancora) vincolanti da un punto di vista giuridico, la GPA è diventata il centro strategico per lo sviluppo di approcci comuni all'auditing di tecnologie complesse e il coordinamento di azioni di enforcement a livello globale⁸⁴. In sintesi, l'auditing della compliance può essere considerato un processo multilivello, in quanto parte dalla mappatura interna (Registro e Data Lineage), si evolve nell'analisi di sistemi complessi (XAI) e culmina nella supervisione che, per essere efficace nell'era odierna, deve essere necessariamente internazionale e cooperativa.

4.4 Approcci interdisciplinari e prospettive future

L'analisi degli strumenti di enactment dimostra che la compliance non può più essere considerata un "box-ticking exercise" ("un esercizio senza impegno"), ma una vera e propria disciplina che vive all'intersezione di aree precedentemente distinte. Il monitoraggio e l'auditing algoritmico (XAI) non sono compiti legali, ma sfide etiche e ingegneristiche. Questa convergenza è la nuova realtà della governance digitale, nella quale la Cybersecurity, la Data Protection e l'AI Governance non sono più silos separati⁸⁵, ma sono diventati un continuum. L'AI Act dell'UE ne è la prova lampante, in quanto si tratta di un regolamento che non può prescindere dal GDPR, ma che, allo stesso tempo, si spinge oltre con l'obiettivo di fornire una norma riguardo ai rischi derivanti dall'uso dei dati (non solo inerente alla raccolta). Questa fusione sposta il focus del dibattito sulla Data Ethics, ovvero l'insieme dei principi morali che guidano l'uso dei dati dove la legislazione non si è ancora espressa oppure è poco chiara⁸⁶. La spinta alla codificazione dei diritti fondamentali di fronte al potere tecnologico, sia privato che statale, alimenta un movimento globale verso un "Digital Constitutionalism"⁸⁷. L'idea è che così come le costituzioni dello scorso secolo hanno limitato il potere statale "analogico", siano necessari nuovi atti

⁸⁰ Lundberg, S., & Lee, S. I. (2017). "A Unified Approach to Interpreting Model Predictions". *Advances in Neural Information Processing Systems (NIPS 2017)*.

⁸¹ Commissione Europea. (2024). "Proposta di Regolamento del Parlamento europeo e del Consiglio che stabilisce regole armonizzate sull'intelligenza artificiale (Legge sull'intelligenza artificiale)". *Testo consolidato (approvato)*.

⁸² Regolamento (UE) 2016/679 (GDPR). Articolo 58 – "Poteri". *EUR-Lex*.

⁸³ European Data Protection Board (EDPB). (s.d.). "Who we are - Cooperation". Sito ufficiale dell'EDPB.

⁸⁴ Global Privacy Assembly (GPA). (s.d.). "About Us - GPA History". Sito ufficiale della GPA.

⁸⁵ International Association of Privacy Professionals (IAPP). (2024). "The Intersection of Privacy and AI Governance". *IAPP Publications*.

⁸⁶ Burr C., Floridi L., Taddeo M. (2019). "The Ethics of Digital Well-Being: A Thematic Review".

⁸⁷ Celeste, E. (2019). "Digital constitutionalism: a new systematic theorisation". *International Review of Law, Computers & Technology*.

per definire i diritti e i limiti del potere nell'odierna era digitale. L'Articolo 8 della Carta UE ("diritto alla protezione dei dati") e la sentenza Puttaswamy in India (che ha elevato la privacy a diritto costituzionale) possono essere considerati come i primi passi verso il costituzionalismo digitale⁸⁸. Questo nascente costituzionalismo digitale rappresenta, in definitiva, il terreno su cui sia etica che ingegneria sono chiamate a negoziare un nuovo (e fondamentale) equilibrio tra l'innovazione tecnologica e la tutela dei diritti della persona.

Conclusioni

Nell'attuale ecosistema digitale, segnato dalla tensione tra innovazione costante e tutela dei diritti fondamentali, il modello europeo di protezione dei dati rappresenta una risposta definita e, allo stesso tempo, influente. Partendo dalla sua genesi filosofica, l'analisi è stata incentrata su come il GDPR non rappresenti solo una normativa tecnica, ma sia l'incarnazione di un diritto fondamentale (Art. 8 della Carta UE) e un pilastro fondamentale per il Mercato Unico Digitale. L'analisi comparativa ha fornito la prova che attesta l'ascesa del GDPR come standard globale. Il modello europeo non si manifesta come un blocco normativo da importare integralmente, ma come un elemento di rottura che ha innescato reazioni complesse e diversificate. In Brasile, ha prodotto uno "specchio" (la LGPD), fortemente ispirata al GDPR per necessità di mercato, ma adattata a specifiche esigenze economiche locali (es. "protezione del credito"). In India, il DPDP Act si è configurato come un "rivale strategico", nato da un impulso costituzionale simile (sentenza Puttaswamy). A differenza del GDPR, il modello indiano si è allontanato dal caratteristico antropocentrismo, privilegiando un approccio più "State-centric", orientato alla sovranità digitale e al controllo governativo. In Giappone, invece, l'APPI si è rivelata un "partner negoziale", un sistema maturo che, attraverso un accordo di adeguatezza reciproca, ha negoziato una convergenza strategica. Questo ha permesso di stabilire un bridge di flussi di dati sicuri, posizionandosi come mediatore globale. La parte dedicata all'analisi dell'Enactment ha rivelato che, nell'era digitale, la conformità non può più essere considerata un disimpegno, ma è diventata una disciplina manageriale, ingegneristica ed etica. Questa disciplina richiede un'impalcatura organizzativa (DPIA, framework ISO/NIST), metodologie proattive (Privacy by Design) e un insieme di PETs. Strumenti come la Differential Privacy o il Federated Learning non sono semplici plus, ma le uniche soluzioni in grado di risolvere il divario tra innovazione e principi fondamentali (Minimizzazione, Art. 5.1.c). L'attuazione, dunque, richiede un monitoraggio e un costante auditing, resi possibili grazie a nuovi strumenti come il Data Lineage e la Explainable AI (XAI). L'intersezione tra Cybersecurity, Data Protection e AI Governance è oramai un continuum, come dimostra la nascita dell'AI Act. La fusione di queste tre aree pone l'attenzione sulla Data Ethics. Questa spinta alla codificazione dei diritti di fronte al potere tecnologico alimenta il Digital Constitutionalism e l'Articolo 8 della Carta UE, insieme alla sentenza Puttaswamy, rappresentano i primi di questo processo. Il futuro, quindi, non risiede nell'adozione di un unico modello globale, ma nella costruzione di un sistema di "interoperabilità" tra i diversi regimi costituzionali. La vera sfida riguarda la creazione di una fiducia digitale reciproca, basata su standard tecnici e governance verificabili. L'adattamento culturale, tecnologico e politico per un enactment efficace non è, in conclusione, un punto d'arrivo, ma il terreno su cui si sta costruendo la società globale dell'informazione.

⁸⁸ Suzor, N. (2018). "Digital Constitutionalism: Using the Rule of Law to Evaluate the Legitimacy of Governance by Platforms". *Queensland University of Technology Legal Studies Research Paper*.

Riferimenti

Agencia de Acceso a la Información Pública (AAIP) (Argentina). Proyecto de Ley de Protección de Datos Personales. Link: <https://www.argentina.gob.ar/aaip/datos-personales/proyecto-de-ley-de-proteccion-de-datos-personales>

Autoridade Nacional de Proteção de Dados (ANPD). Sito Ufficiale. Link: <https://www.gov.br/anpd/pt-br>

Boucher, P. (1974). "SAFARI ou la chasse aux Français". Le Monde, 21 marzo 1974. Link: https://www.cnil.fr/sites/default/files/atoms/files/le_monde_0.pdf

Bradford, A. (2020). The Brussels Effect: How the European Union Rules the World. Oxford University Press. Link: <https://global.oup.com/academic/product/the-brussels-effect-9780190088583>

Bundesverfassungsgericht (Corte Costituzionale Federale Tedesca). (1983). Sentenza sul censimento (Volkszählungsurteil). Link: <https://germanlawarchive.iuscomp.org/law?id=202>

Burr C., Floridi L., Taddeo M. (2019). "The Ethics of Digital Well-Being: A Thematic Review". Link: https://www.researchgate.net/publication/331231431_The_Ethics_of_Digital_Well-Being_A_Thematic_Review

Cavoukian, A. (2011). "Privacy by Design: The 7 Foundational Principles". Information and Privacy Commissioner of Ontario, Canada. Link: <https://www.ipc.on.ca/wp-content/uploads/2016/08/pbd-7-principles.pdf>

Celeste, E. (2019). "Digital constitutionalism: a new systematic theorisation". International Review of Law, Computers & Technology. Link: <https://researchrepository.ucd.ie/entities/publication/ce4633af-794c-43b6-a90e-855f0e6904ec>

Center for Strategic and International Studies (CSIS). (2019). "Japan's G20 Leadership on Data Governance". Link: <https://www.csis.org/analysis/japans-g20-leadership-data-governance>

Commissione Europea, "La Commissione e il Giappone avviano il dialogo per facilitare i flussi di dati" (Comunicato stampa, 2017). Link: https://ec.europa.eu/commission/presscorner/detail/en/IP_17_8

Commissione Europea. (2003). Decisione 2003/490/CE [...] relativa all'adeguata protezione dei dati personali in Argentina. Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:32003D0490>

Commissione Europea. (2012). Proposta di Regolamento del Parlamento europeo e del Consiglio concernente la tutela delle persone fisiche con riguardo al trattamento dei dati personali e la libera circolazione di tali dati (Regolamento generale sulla protezione dei dati). COM(2012) 11 final. Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:52012PC0011>

Commissione Europea. (2015). Comunicazione sulla Strategia per il mercato unico digitale in Europa. COM(2015) 192 final. Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:52015DC0192>

Commissione Europea. (2019). "Decisione di esecuzione (UE) 2019/419 della Commissione, del 23 gennaio 2019, relativa all'adeguatezza della protezione dei dati personali in Giappone". Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:32019D0419>

Commissione Europea. (2019). "EU-Japan create the world's largest area of safe data flows". Link: https://ec.europa.eu/commission/presscorner/detail/en/IP_19_42

Commissione Europea. (2020). Comunicazione della Commissione [...] Due anni di applicazione del regolamento generale sulla protezione dei dati. COM(2020) 264 final (pag.10-11). Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:52020DC0264>

Commissione Europea. (2024). "Proposta di Regolamento del Parlamento europeo e del Consiglio che stabilisce regole armonizzate sull'intelligenza artificiale (Legge sull'intelligenza artificiale)". Testo consolidato (approvato). Link: <https://data.consilium.europa.eu/doc/document/ST-5662-2024-INIT/it/pdf>

Commissione Europea. Decisioni di adeguatezza. Link: https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/adequacy-decisions_it

Corte di Giustizia dell'Unione Europea (CJEU). (2014). Sentenza Google Spain SL e Google Inc. contro Agencia Española de Protección de Datos (AEPD) e Mario Costeja González. Link: <https://curia.europa.eu/juris/liste.jsf?num=C-131/12>

Corte di Giustizia dell'Unione Europea (CJEU). (2014). Sentenza nelle cause riunite C-293/12 e C-594/12, Digital Rights Ireland Ltd e Seitlinger e altri. Link: <https://curia.europa.eu/juris/liste.jsf?num=C-293/12>

Corte di Giustizia dell'Unione Europea (CJEU). (2020). Sentenza nella Causa C-311/18, Data Protection Commissioner c. Facebook Ireland Ltd e Maximillian Schrems ("Schrems II"). Link: <https://curia.europa.eu/juris/liste.jsf?num=C-311/18>

DAMA International. (2017). "DAMA-DMBOK: Data Management Body of Knowledge (2nd Edition)". DAMA International. Link: <https://www.dama.org/cpages/body-of-knowledge>

DARPA (Defense Advanced Research Projects Agency). "Explainable Artificial Intelligence (XAI)". DARPA Programs. Link: <https://www.darpa.mil/program/explainable-artificial-intelligence>

DifferentialPrivacy.org. (s.d.). "Who uses differential privacy?". Link: <https://differentialprivacy.org/>

Direttiva 95/46/CE del Parlamento europeo e del Consiglio, del 24 ottobre 1995, relativa alla tutela delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati. Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:31995L0046>

DLA Piper. (2022). "Japan: Key changes under the amended APPI". DLA Piper Publications. Link: <https://www.dlapiper.com/en/insights/publications/2022/03/japan-key-changes-under-the-amended-appi>

Dwork, C., & Roth, A. (2014). "The Algorithmic Foundations of Differential Privacy". Foundations and Trends in Theoretical Computer Science. Link: https://www.cis.upenn.edu/~aaroht/Papers/privacy_book.pdf

ENISA (European Union Agency for Cybersecurity). (2021). "Privacy Enhancing Technologies - An overview". Link: <https://www.enisa.europa.eu/publications/privacy-enhancing-technologies>

European Added Value Unit (EPRS). (2020). The cost of non-Europe in 'The General Data Protection Regulation'. Parlamento Europeo. Link:

[https://www.europarl.europa.eu/RegData/etudes/STUD/2020/642823/EPRS_STU\(2020\)642823_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/STUD/2020/642823/EPRS_STU(2020)642823_EN.pdf)

European Data Protection Board (EDPB). (2017). "Linee guida concernenti la valutazione di impatto sulla protezione dei dati nonché i criteri per stabilire se un trattamento 'possa presentare un rischio elevato' ai sensi del regolamento 2016/679" (WP 248 rev.01). Link:

https://www.edpb.europa.eu/our-work-tools/our-documents/linee-guida/linee-guida-concernenti-la-valutazione-di-impatto_it

European Data Protection Board (EDPB). (2021). Raccomandazioni 01/2020 sulle misure che integrano gli strumenti di trasferimento a garanzia del rispetto del livello di protezione....

(Versione 2.0). Link: https://www.edpb.europa.eu/system/files/2021-06/edpb_recommendations_202001vo.2.0_supplementarymeasures_it.pdf

European Data Protection Board (EDPB). (s.d.). "Who we are - Cooperation". Sito ufficiale dell'EDPB. Link: https://www.edpb.europa.eu/about-edpb/who-we-are/cooperation_en

European Data Protection Board (EDPB). Sito Ufficiale. Link: <https://www.edpb.europa.eu/>

European Data Protection Supervisor (EDPS). (2016). Opinion 8/2016: EDPS Opinion on the coherent enforcement of fundamental rights in the age of Big Data. Link:

https://edps.europa.eu/data-protection/our-work/publications/opinions/big-data-coherent-enforcement_en

Finck, M. (2018). "Blockchains and Data Protection in the European Union". European Data Protection Law Review. Link: <https://edpl.lexxion.eu/article/EDPL/2018/1/6>

Finck, M. (2018). Blockchain and the General Data Protection Regulation: Can decentralized technologies be squared with European data protection law?. European Parliament Policy Department for Citizens' Rights and Constitutional Affairs. Link:

[https://www.europarl.europa.eu/RegData/etudes/STUD/2019/634445/IPOL_STU\(2019\)634445_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/STUD/2019/634445/IPOL_STU(2019)634445_EN.pdf)

Gartner. (s.d.). "Data Lineage". Gartner Glossary. Link: <https://www.gartner.com/en/information-technology/glossary/data-lineage>

Global Privacy Assembly (GPA). (s.d.). "About Us - GPA History". Sito ufficiale della GPA. Link: <https://globalprivacyassembly.org/about-us/gpa-history/>

Goodman, B., & Flaxman, S. (2017). European Union regulations on algorithmic decision-making and a 'right to explanation'. AI Magazine, 38(3), 50-57. Link:

<https://ojs.aaai.org/index.php/aimagazine/article/view/2741>

Google AI Blog. (2017). "Federated Learning: Collaborative Machine Learning without Centralized Training Data". Link: <https://ai.googleblog.com/2017/04/federated-learning-collaborative.html>

Datalagen. Link: https://www.riksdagen.se/sv/dokument-lagar/dokument/svensk-forfattningssamling/datalag-1973289_sfs-1973-289

IETF (Internet Engineering Task Force). (2012). "RFC 6749: The OAuth 2.0 Authorization Framework". Link: <https://datatracker.ietf.org/doc/html/rfc6749>

International Association of Privacy Professionals (IAPP). (2017). "A closer look at Japan's 'anonymously processed information'". Link: <https://iapp.org/news/a/a-closer-look-at-japans-anonymously-processed-information/>

International Association of Privacy Professionals (IAPP). (2024). "The Intersection of Privacy and AI Governance". IAPP Publications. Link: <https://iapp.org/resources/article/the-intersection-of-privacy-and-ai-governance/>

International Organization for Standardization (ISO). (2019). "ISO/IEC 27701:2019 - Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines". Link: <https://www.iso.org/standard/71670.html>

Internet Freedom Foundation (IFF) (2023). The DPDP Act, 2023: An analysis of 'deemed consent'. Link: <https://iff.in/dpdp-act-2023-analysis-of-deemed-consent/>

Jia, Y., & R. L. R. (2018). The unintended consequences of the GDPR on digital innovation. SSRN. Link: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=3277747

K.S. Puttaswamy (Retd.) and Ors. vs. Union of India and Ors. (2017) 10 SCC 1. Link: https://main.sci.gov.in/supremecourt/2012/35071/35071_2012_Judgement_24-Aug-2017.pdf

Loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés. Link: <https://www.legifrance.gouv.fr/loda/id/JORFTEXT000000886460/1978-01-07/>

Lundberg, S., & Lee, S. I. (2017). "A Unified Approach to Interpreting Model Predictions". Advances in Neural Information Processing Systems (NIPS 2017). Link: <https://arxiv.org/abs/1705.07874>

Ministerio de Justicia y Derechos Humanos (Argentina). (2000). Ley 25.326 - Protección de los Datos Personales. Link: <https://servicios.infoleg.gob.ar/infolegInternet/anexos/60000-64999/64790/texact.htm>

National Institute of Standards and Technology (NIST). (2020). "NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management (Version 1.0)". Link: <https://www.nist.gov/privacy-framework>

NIST (National Institute of Standards and Technology). (2020). "SP 800-207: Zero Trust Architecture". Link: <https://csrc.nist.gov/publications/detail/sp/800-207/final>

NOYB - European Center for Digital Rights. (2023). Schrems challenges new EU-US data deal ("Privacy Shield 3.0"). Link: <https://noyb.eu/en/schrems-challenges-new-eu-us-data-deal-privacy-shield-30>

NOYB. (2023). Five Years GDPR: A Look Back at the Biggest Cases. Link: <https://noyb.eu/en/noyb-files-4-complaints-over-cookie-banner-terror>

Organisation for Economic Co-operation and Development (OECD). (1980). Guidelines on the Protection of Privacy and Transborder Flows of Personal Data. Parigi: OECD Publishing. Link: <https://www.oecd.org/internet/ieconomy/oecdguidelinesontheProtectionofPrivacyandTransborderFlowsOfPersonalData.htm>

Parlamento europeo e Consiglio. (2016). Regolamento (UE) 2016/679 (GDPR). Articolo 5, "Principi applicabili al trattamento di dati personali". Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/HTML/?uri=CELEX:32016R0679&from=IT#d1e1887-1-1>

Parlamento europeo e Consiglio. (2016). Regolamento (UE) 2016/679 (GDPR). Articolo 17, "Diritto alla cancellazione ('diritto all'oblio)". Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/HTML/?uri=CELEX:32016R0679&from=IT#d1e2613-1-1>

Parlamento europeo e Consiglio. (2024). Regolamento [...] che stabilisce regole armonizzate sull'intelligenza artificiale (Legge sull'intelligenza artificiale). Link: https://www.europarl.europa.eu/doceo/document/TA-9-2024-0138_IT.html

Personal Information Protection Commission of Japan (PPC). (2017). "Establishment of the Personal Information Protection Commission and the 2015 Amendments to the APPI". Link: <https://www.ppc.go.jp/en/legal/>

Personal Information Protection Commission of Japan (PPC). (2019). "Supplementary Rules under the Act on the Protection of Personal Information for handling personal data transferred from the EU based on an adequacy decision". Link: https://www.ppc.go.jp/files/pdf/Supplementary_Rules.pdf

Presidência da República (Brasile). (2018). Lei Nº 13.709, de 14 de Agosto de 2018 (Lei Geral de Proteção de Dados Pessoais - LGPD). Link: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/113709.htm

Rajagopalan, R., & S. B. P. (2023). India's Digital Sovereignty: The Data Protection Bill in Context. Observer Research Foundation (ORF). Link: <https://www.orfonline.org/research/india-s-digital-sovereignty-the-data-protection-bill-in-context>

Regolamento (UE) 2016/679 (GDPR). Articolo 22 – "Processo decisionale automatizzato relativo alle persone fisiche, compresa la profilazione". Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/HTML/?uri=CELEX:32016R0679#d1e2925-1-1>

Regolamento (UE) 2016/679 (GDPR). Articolo 25 – "Protezione dei dati fin dalla progettazione e protezione dei dati per impostazione predefinita". EUR-Lex. Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/HTML/?uri=CELEX:32016R0679#d1e3137-1-1>

Regolamento (UE) 2016/679 (GDPR). Articolo 30 – "Registri delle attività di trattamento". Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/HTML/?uri=CELEX:32016R0679#d1e3448-1-1>

Regolamento (UE) 2016/679 (GDPR). Articolo 58 – "Poteri". EUR-Lex. Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/HTML/?uri=CELEX:32016R0679#d1e5170-1-1>

Ribeiro, M. T., Singh, S., & Guestrin, C. (2016). "Why Should I Trust You?": Explaining the Predictions of Any Classifier". Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining. Link: <https://arxiv.org/abs/1602.04938>

Rodotà, S. (2012). Il diritto di avere diritti. Bari: Laterza.

Samarati, P. & Sweeney, L. (1998). "Protecting privacy when disclosing information: k-anonymity and its enforcement through generalization and suppression". Link: https://epic.org/wp-content/uploads/privacy/reidentification/Samarati_Sweeney_paper.pdf

Simitis, S. (1987). "Reviewing Privacy in an Information Society". University of Pennsylvania Law Review, 135(3), 707-746. Link: https://scholarship.law.upenn.edu/penn_law_review/vol135/iss3/3/

Superintendencia de Industria y Comercio (SIC) (Colombia). Sito Ufficiale - Protección de Datos. Link: <https://www.sic.gov.co/proteccion-de-datos-personales>

Suzor, N. (2018). "Digital Constitutionalism: Using the Rule of Law to Evaluate the Legitimacy of Governance by Platforms". Queensland University of Technology. Link: https://www.researchgate.net/publication/326455750_Digital_Constitutionalism_Using_the_Rule_of_Law_to_Evaluate_the_Legitimacy_of_Governance_by_Platforms

Sweeney, L. (2002). "k-Anonymity: A Model for Protecting Privacy". International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems. Link: https://epic.org/privacy/reidentification/Sweeney_k-anonymity.pdf

The Digital Personal Data Protection Act, 2023 (Act No. 22 of 2023). Testo ufficiale della legge pubblicato dal Ministry of Electronics and Information Technology (MeitY). Link: <https://www.meity.gov.in/writereaddata/files/Digital%20Personal%20Data%20Protection%20Act%202023.pdf>

The Government of India (2023). The Digital Personal Data Protection Act, 2023 (No. 22 of 2023). The Gazette of India. Link: <https://egazette.gov.in/WriteReadData/2023/248439.pdf>

Trattato sul Funzionamento dell'Unione Europea (TFUE) (Versione consolidata 2012/C 326/01). Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:12012E/TXT>

Trattato sull'Unione Europea (TUE) (Versione consolidata 2012/C 326/01). Link: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:12012M/TXT>

Voigt, P., & von dem Bussche, A. (2017). The EU General Data Protection Regulation (GDPR): A Practical Guide. Springer. Link: <https://link.springer.com/book/10.1007/978-3-031-62328-8>

W3C (World Wide Web Consortium). (2022). "Verifiable Credentials Data Model v1.1". Link: <https://www.w3.org/TR/vc-data-model/>

Warren, S. D., & Brandeis, L. D. (1890). "The Right to Privacy". Harvard Law Review, 4(5), 193-220. Link: <https://www.jstor.org/stable/1321160?origin=crossref&seq=19>

Zero Trust Architecture. Link: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>